Burp Workbench KR

0.19.0 / 번호 그림으로 따라 하는 확장 사용 가이드

트래픽에서 시작하는 취약점 점검 가이드북

SCOPE 등록 > 기능 실행 > 근거 확인 > 누락 점검

화면의 1·2·3·4 번호와 바로 아래 설명을 순서대로 따라 하세요. 번호는 각 그림에서 다시 1부터 시작합니다.

포함 기능: 트래픽·SCOPE, 권한 비교, 변환·JWT·데이터 비교, JS 추출, 환경 탐색, URL 수집, 활동 추적, 페이로드 검사, Passive·API 문서·저장/조회 연결, 공통 설정, 세션·권한 매트릭스, 외부 도구, 순차 업무 흐름, OAST, 증거 ZIP, 브라우저 검증.

이미지 안내: 배포 JAR 0.19.0의 실제 Swing UI 컴포넌트를 창 없이 렌더링하고 실습 데이터를 넣었습니다. 실제 Burp 데스크톱을 캡처한 화면은 아닙니다. 팝업은 내용 영역 중심으로 표시하며 테마·창 크기에 따라 배치가 달라질 수 있습니다. 화면 번호는 문서에서 덧붙였습니다.

읽기 팁: 화면은 확대해서 읽는 디지털 가로형 PDF입니다. 함께 제공하는 HTML에서는 그림을 클릭해 확대할 수 있습니다. 예시 대상은 http://127.0.0.1:8088이며 실제 진단은 허용된 점검 범위에 맞춰 진행하세요.

목차와 기능별 진입 위치 1

기능 이름을 클릭하면 해당 페이지로 이동합니다.

시작과 SCOPE

- 트래픽에서 작업을 시작하기 05
- 우클릭으로 SCOPE 등록하기 06
- SCOPE 창에서 범위 관리하기 07
- 트래픽을 기능별로 전달하기 08

권한 비교

- 권한 비교용 인증 후보 모으기 09
- Alice·Bob·비로그인 슬롯 지정 10
- 인가 정책과 비교 기준 설정 11
- 비교 실행과 결과 읽기 12

데이터 도구

- 데이터 변환 사용하기 13
- JWT 내용과 시간 확인하기 14
- JSON·XML·HTTP 데이터 비교 15

JS 추출

- JS에서 API와 후보 정보 찾기 16
- JS의 기준 URL 설정 17
- 동적 URL을 실제 값으로 확정 18

환경 탐색

- 환경 관찰과 경로 후보 확인 19
- 없는 경로와 응답 안정성 비교 20

URL 수집

- URL 수집과 GET 검증 구분 21
- URL 패턴과 대표 요청 관리 22

활동 추적

- 활동 추적으로 빠진 점검 찾기 23
- 수동 완료 처리와 근거 보관 24

페이로드 검사

- 페이로드 검사 요청 준비 25
- 검사 후보 편집과 실행 26
- 검사 설정 창 사용하기 27

4쪽에서 확장 진입 순서를 확인하세요. 기능 설명 뒤에는 “제가 점검을 시작한다면” 전체 사이트 점검 예시 4쪽이 이어집니다.

목차와 기능별 진입 위치 2

기능 이름을 클릭하면 해당 페이지로 이동합니다.

응답 분석

Passive 응답 관찰 읽기 28
OpenAPI에서 요청 초안 만들기 29
API 템플릿 경로 확정 30
저장/조회 검증용 마커 등록 31
저장 결과가 조회에 나타나는지 확인 32

공통 설정

설정은 현재 화면을 유지한 채 열기 33

세션·권한 매트릭스

계정 세션과 기대 권한 설정 34

점검 지원 · 외부 도구

기존 도구로 검사하고 발견 이름 연결 35

점검 지원 · 업무 흐름

여러 요청을 순서대로 재현 36
업무 흐름 실행 설정 37

점검 지원 · OAST

OAST 상호작용을 원본 요청과 연결 38

점검 지원 · 증거

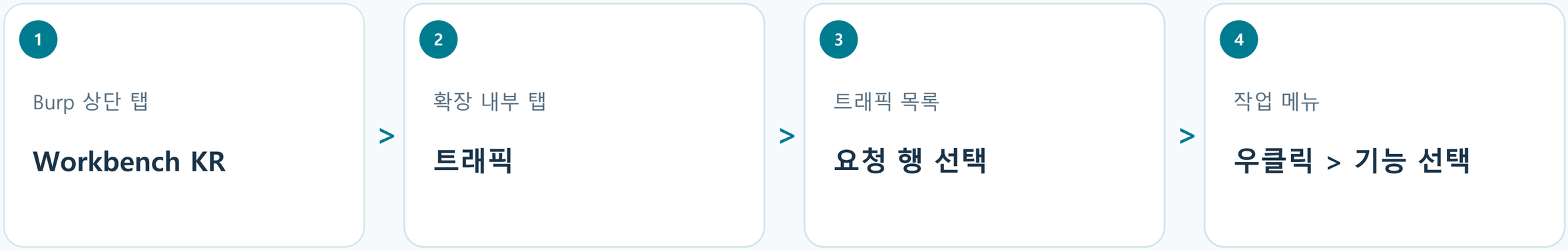
재현 증거를 ZIP으로 보관 39
실제 브라우저 실행 근거 연결 40

4쪽에서 확장 진입 순서를 확인하세요. 기능 설명 뒤에는 "제가 점검을 시작한다면" 전체 사이트 점검 예시 4쪽이 이어집니다.

00 Burp에서 확장 화면 열기

Burp 상단 Workbench KR > 내부 트래픽 > 요청 선택

아래 그림은 진입 순서도입니다. Burp 화면 캡처가 아니며, 이미 JAR를 로드한 상태를 기준으로 설명합니다.



1 JAR 로드 여부 확인

Burp 확장 관리의 Java 확장 추가 화면에서 burp-workbench-kr-0.19.0.jar를 선택합니다. 로드 후 상단에 Workbench KR 탭이 나타나는지 확인합니다.

2 트래픽 확보

Burp 프록시를 사용하는 브라우저에서 실습 사이트를 열어 요청을 발생시킵니다. 프록시 Intercept가 요청을 붙잡고 있으면 전달한 뒤 응답을 확인합니다.

3 먼저 SCOPE 등록

처음 보이는 요청 행을 우클릭하고 SCOPE 지정으로 범위를 등록합니다. History 화면에서 별도로 범위를 지정할 필요 없이 확장 트래픽에서 관리합니다.

4 기능으로 전달

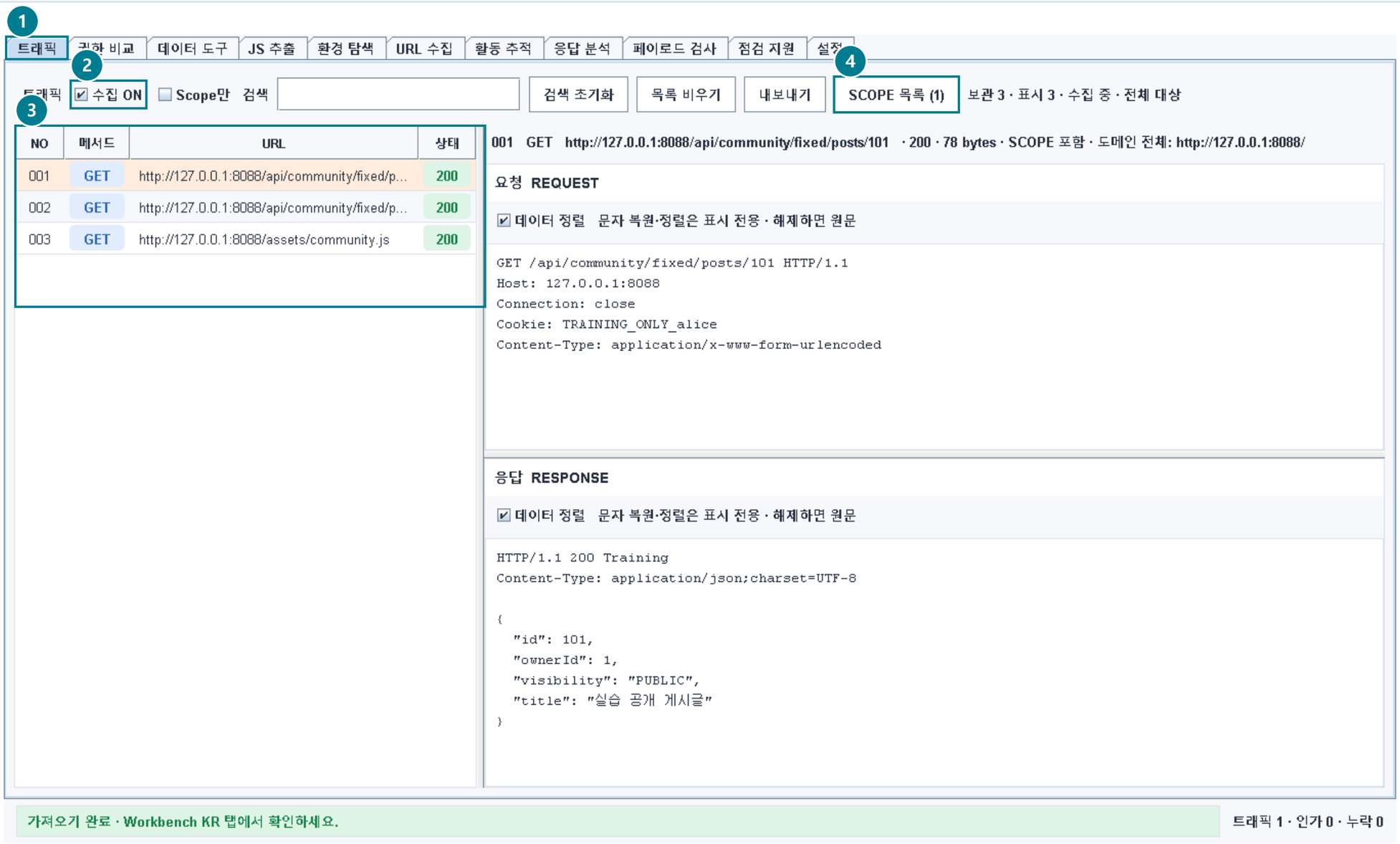
같은 요청을 권한 비교·JS 추출·페이로드 검사 등으로 전달합니다. 계정 비교와 검사는 설정을 확인한 후 실행하고 결과 근거를 보관합니다.

Workbench KR 탭이 안 보이면 확장 관리 화면의 로드 상태와 오류 출력을 확인하세요. 요청이 안 보이면 수집 ON, 프록시 연결, 표시 필터를 확인합니다.

01 트래픽에서 작업을 시작하기

Burp 상단 Workbench KR > 트래픽

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 트래픽 탭 클릭

Burp 상단의 Workbench KR을 먼저 연 뒤 내부 트래픽 탭을 선택합니다. 여기서 요청을 선택해 각 도구로 전달합니다.

2 트래픽 수집 켜기

체크된 상태에서 Burp를 통과하는 요청과 응답이 목록에 쌓입니다. 브라우저가 Burp 프록시를 사용하고 있는지 확인합니다.

3 요청 행 선택

왼쪽 목록의 URL을 클릭합니다. 오른쪽에 선택 요청과 응답이 표시됩니다. 이 행을 우클릭하면 기능 메뉴가 열립니다.

4 SCOPE 목록 열기

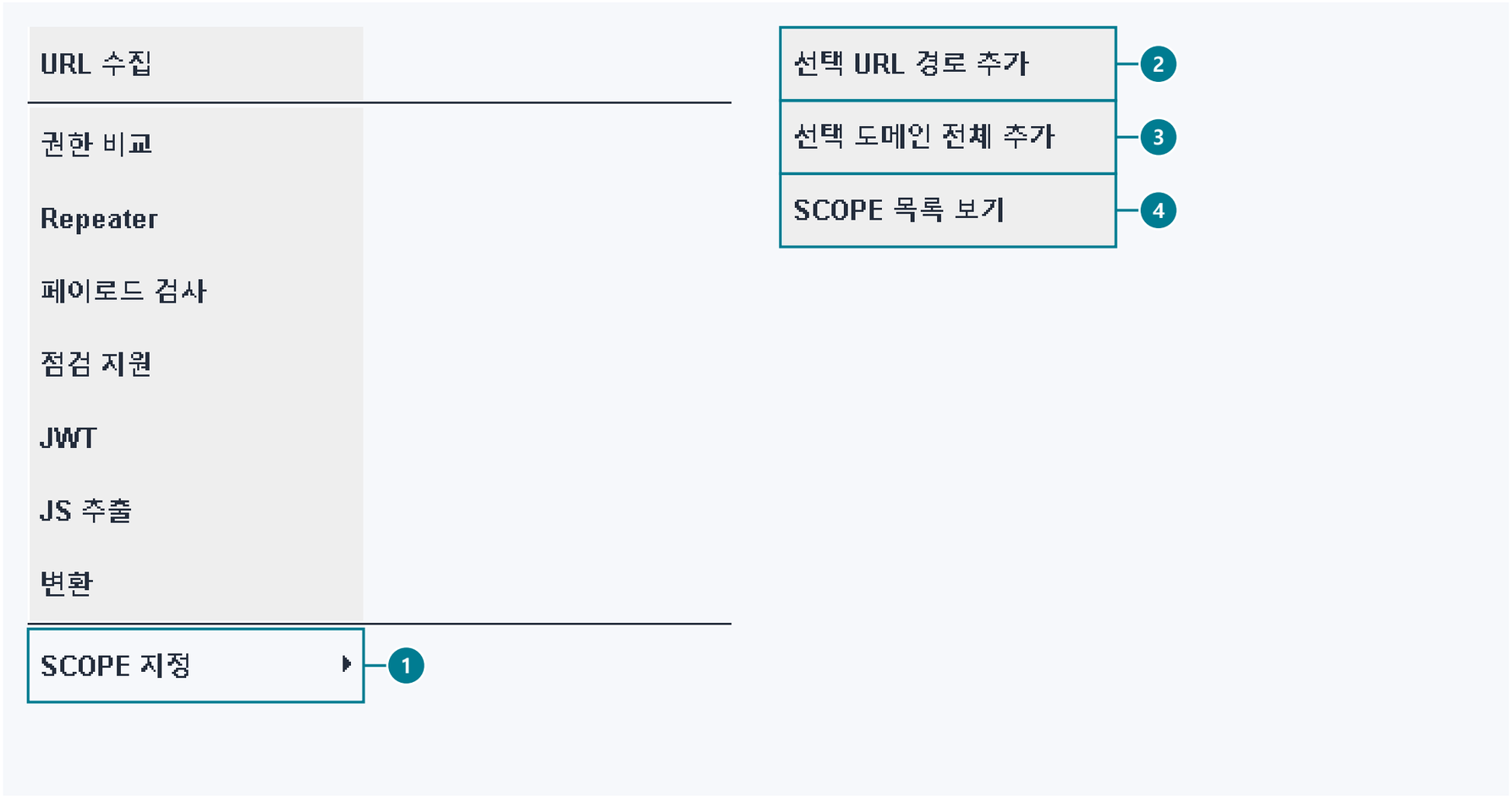
등록한 범위를 별도 창에서 확인합니다. 현재 보고 있는 트래픽 화면과 선택 상태는 유지됩니다.

Scope만은 표시 대상을 줄이는 필터입니다. 점검 범위 자체는 다음 페이지의 우클릭 메뉴로 등록하세요. 데이터 정렬은 표시용이며 전송 원문을 바꾸지 않습니다.

02 우클릭으로 SCOPE 등록하기

트래픽 > 요청 행 우클릭 > SCOPE 지정

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링 · 메뉴 내용을 나란히 펼침



1 SCOPE 지정 메뉴 열기

선택한 트래픽 행을 우클릭한 뒤 SCOPE 지정에 마우스를 올립니다. 그림은 실제 메뉴 항목을 나란히 펼친 예시입니다.

2 URL 경로만 등록

선택 URL의 경로와 그 하위 경로를 포함합니다. 예: /api/community/fixed/posts/101은 해당 경로를 기준으로 등록됩니다. 쿼리 값은 규칙에 저장하지 않습니다.

3 같은 Origin 전체 등록

같은 프로토콜·호스트·포트의 모든 경로를 포함합니다. 실습 사이트 전체를 점검할 때는 http://127.0.0.1:8088/ 범위가 편리합니다.

4 등록 내용 확인

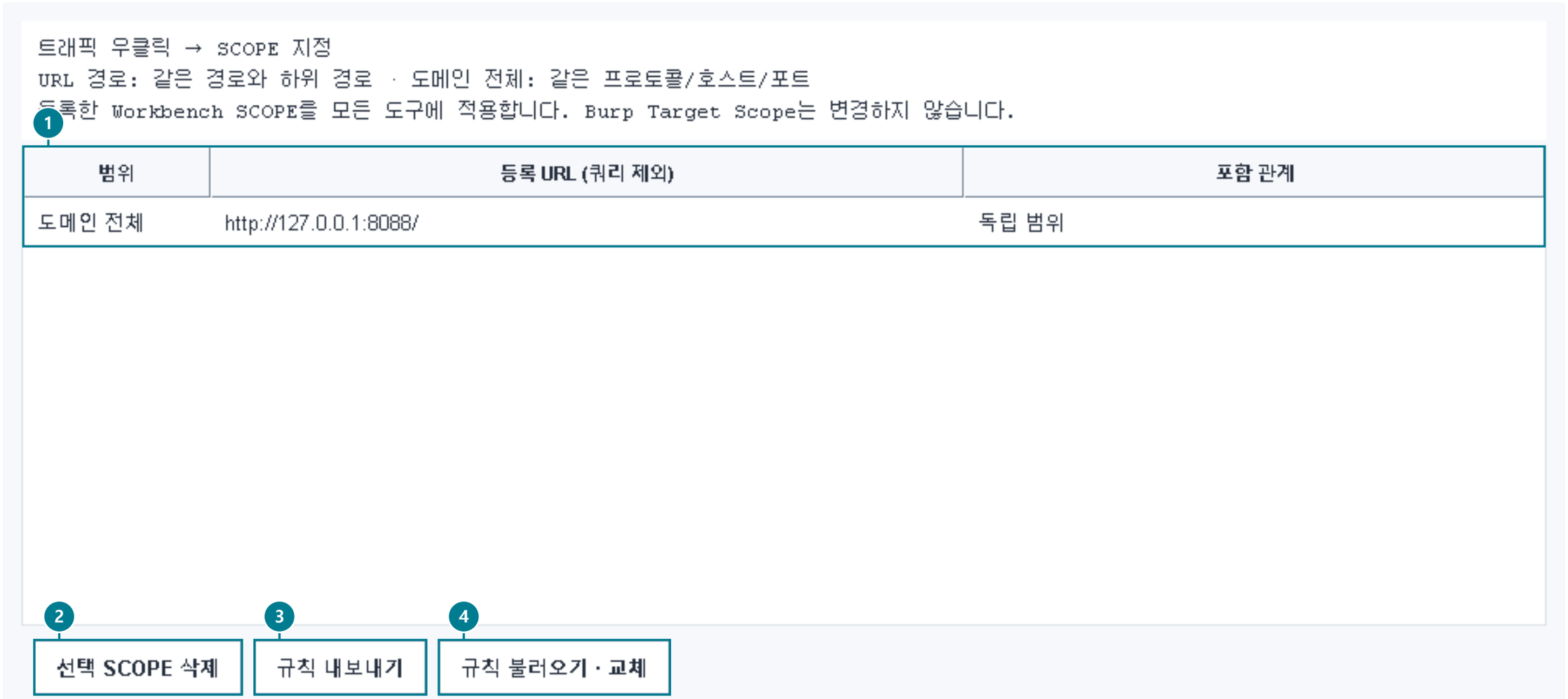
이 메뉴 또는 트래픽 상단 SCOPE 목록 버튼으로 범위를 확인합니다. 각 기능에 URL을 반복 입력하기 전에 여기서 대상 범위를 관리합니다.

Workbench SCOPE는 이 확장의 도구들이 공유하는 범위입니다. Burp의 Target Scope 자체는 변경되지 않습니다. 도메인 전체 규칙은 URL 경로 규칙보다 넓습니다.

03 SCOPE 창에서 범위 관리하기

트래픽 > SCOPE 목록

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 등록 URL과 포함 관계 확인

범위 종류, 등록 URL, 다른 규칙과의 포함 관계를 확인합니다. 같은 대상의 넓은 규칙과 좁은 규칙이 함께 있으면 넓은 규칙도 적용됩니다.

2 필요 없는 규칙 삭제

삭제할 행을 선택하고 누릅니다. 전체 도메인 규칙을 지워야 특정 경로만 남길 수 있습니다. 마지막 규칙까지 지우면 이 확장의 점검 범위가 비게 됩니다.

3 범위 파일 보관

현재 규칙을 파일로 저장합니다. 다음 점검에서 같은 범위를 복원할 때 사용합니다.

4 기존 범위를 교체

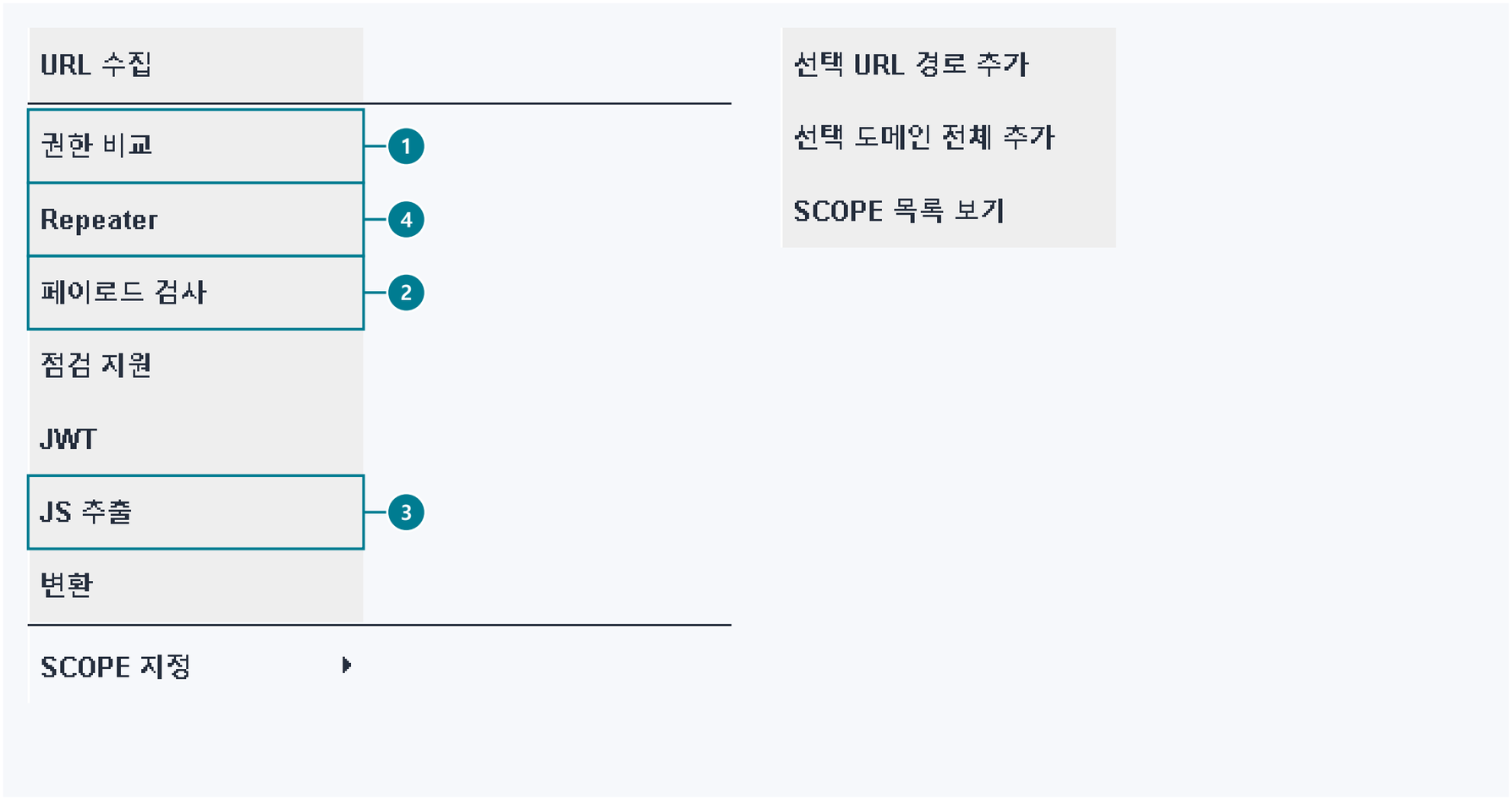
저장한 파일로 현재 규칙을 교체합니다. 추가 합치기가 아니므로 교체 후 목록을 확인합니다.

SCOPE 목록은 별도 창입니다. 창을 닫아도 트래픽 탭은 그대로 유지됩니다.

04 트래픽을 기능별로 전달하기

트래픽 > 요청 행 우클릭

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링 · 메뉴 내용을 나란히 펼침



1 계정별 인가 비교

먼저 권한 비교 탭에서 계정 후보와 정책을 설정한 뒤 사용합니다. 선택 요청을 다른 계정으로 재전송해 비교하므로 실제 HTTP 요청이 발생합니다.

2 선택 요청으로 검사 준비

요청을 검사 편집기에 가져옵니다. 값 하나를 교체 위치로 지정하고 설정을 확인한 뒤 시작을 눌러야 검사가 실행됩니다.

3 선택 응답의 JS 분석

JS 응답을 가져와 URL/API, 키 후보, 의존성 등을 정적으로 분석합니다. 선택 원본은 JS 추출 탭에서 다시 확인할 수 있습니다.

4 수동 재현 준비

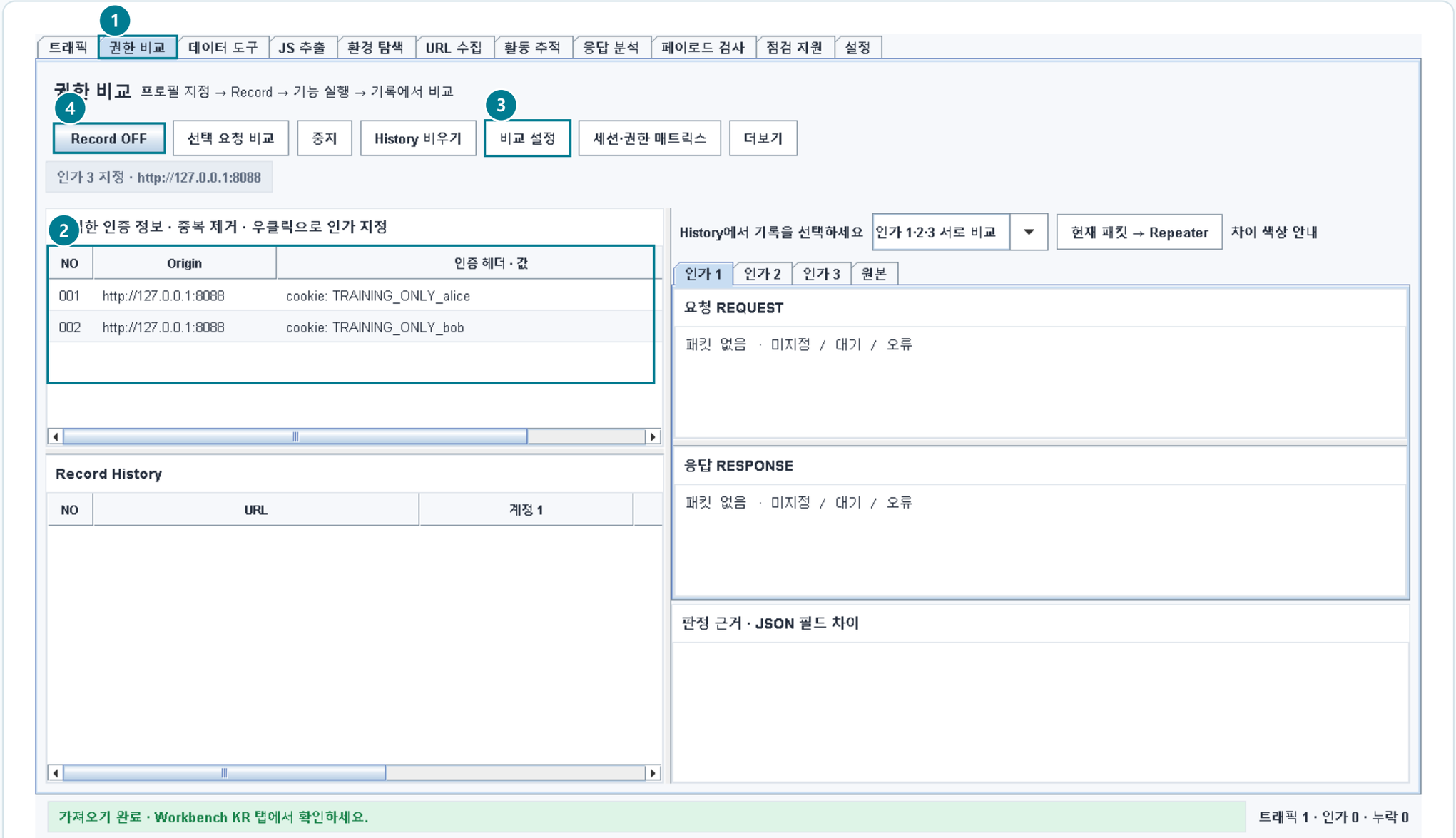
선택 요청을 Burp Repeater로 보냅니다. Repeater에서 값·인증·본문을 확인하고 Send를 눌러 직접 요청합니다.

다른 항목: URL 수집은 대상 URL 수집 화면으로 전달, JWT는 토큰 분석, 변환은 데이터 변환으로 연결합니다. 메뉴 선택과 실제 전송 여부는 기능마다 다릅니다.

05 권한 비교용 인증 후보 모으기

Workbench KR > 권한 비교

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 권한 비교 탭 열기

SCOPE 내 사이트에서 Alice와 Bob으로 각각 로그인해 요청을 발생시킵니다. Cookie와 인증 관련 헤더가 있는 요청이 후보 목록에 기록됩니다.

2 후보 행 선택 후 우클릭

인증 후보는 Origin과 함께 관리됩니다. 원하는 계정의 후보를 클릭하고 우클릭해 계정 슬롯에 지정합니다. 실제 Cookie는 보고서 공유 전에 가리세요.

3 계정 이름과 정책 설정

계정 이름, 소유자 ID, 소유 JSON 경로, 접근 정책을 설정합니다. 다음 페이지부터 지정 순서와 예시를 설명합니다.

4 Record OFF 상태에서 준비

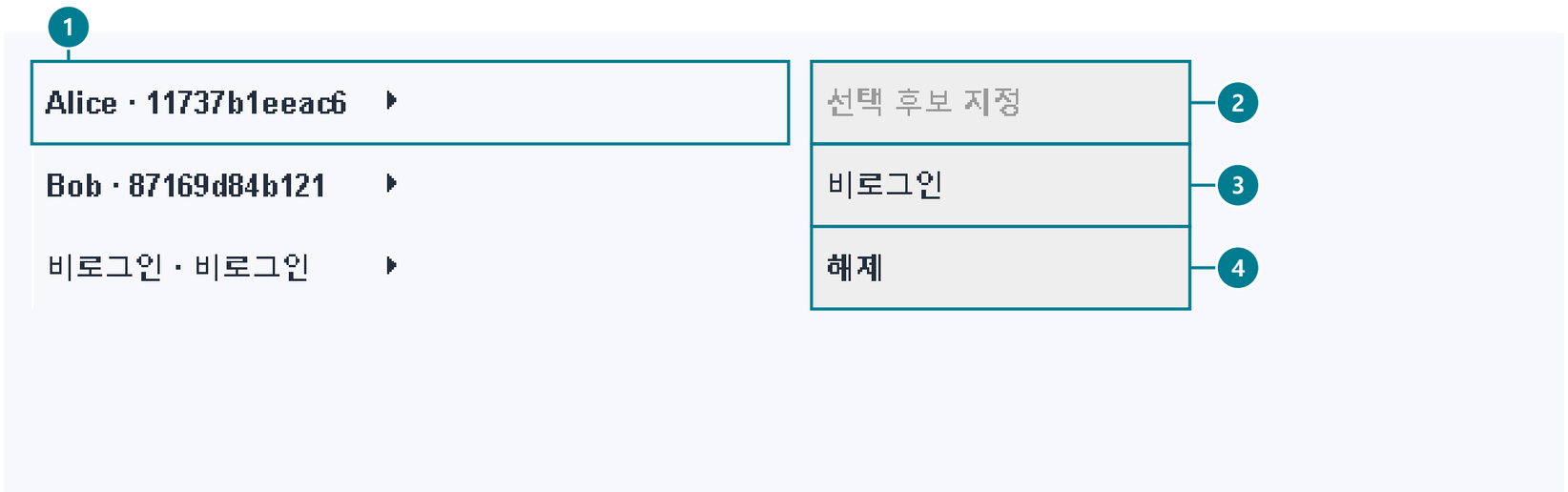
계정·정책 설정이 끝날 때까지 OFF로 둡니다. ON으로 바꾸면 이후 범위 내 요청을 계정별로 자동 재전송합니다.

예시 Cookie는 TRAINING_ONLY 값입니다. 자동으로 수집되는 인증 후보 목록과 명시적으로 실행하는 계정별 재전송을 구분하세요.

06 Alice·Bob·비로그인 슬롯 지정

권한 비교 > 인증 후보 행 우클릭

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링 · 메뉴 내용을 나란히 펼침



1 계정 슬롯 선택

인가 1에 Alice, 인가 2에 Bob을 지정하는 식으로 슬롯을 나눕니다. 계정 이름은 비교 설정에서 바꿀 수 있습니다.

2 선택한 후보 적용

후보 행을 먼저 선택해야 활성화됩니다. 그림의 메뉴는 열린 항목을 보여 주는 예시이므로 선택 후보 지정이 비활성 상태로 보입니다.

3 인증을 제거한 슬롯 사용

인가 3은 비로그인으로 지정합니다. 별도 로그인 세션 후보를 지정하지 않고 인증을 제거한 비교에 사용합니다.

4 슬롯 초기화

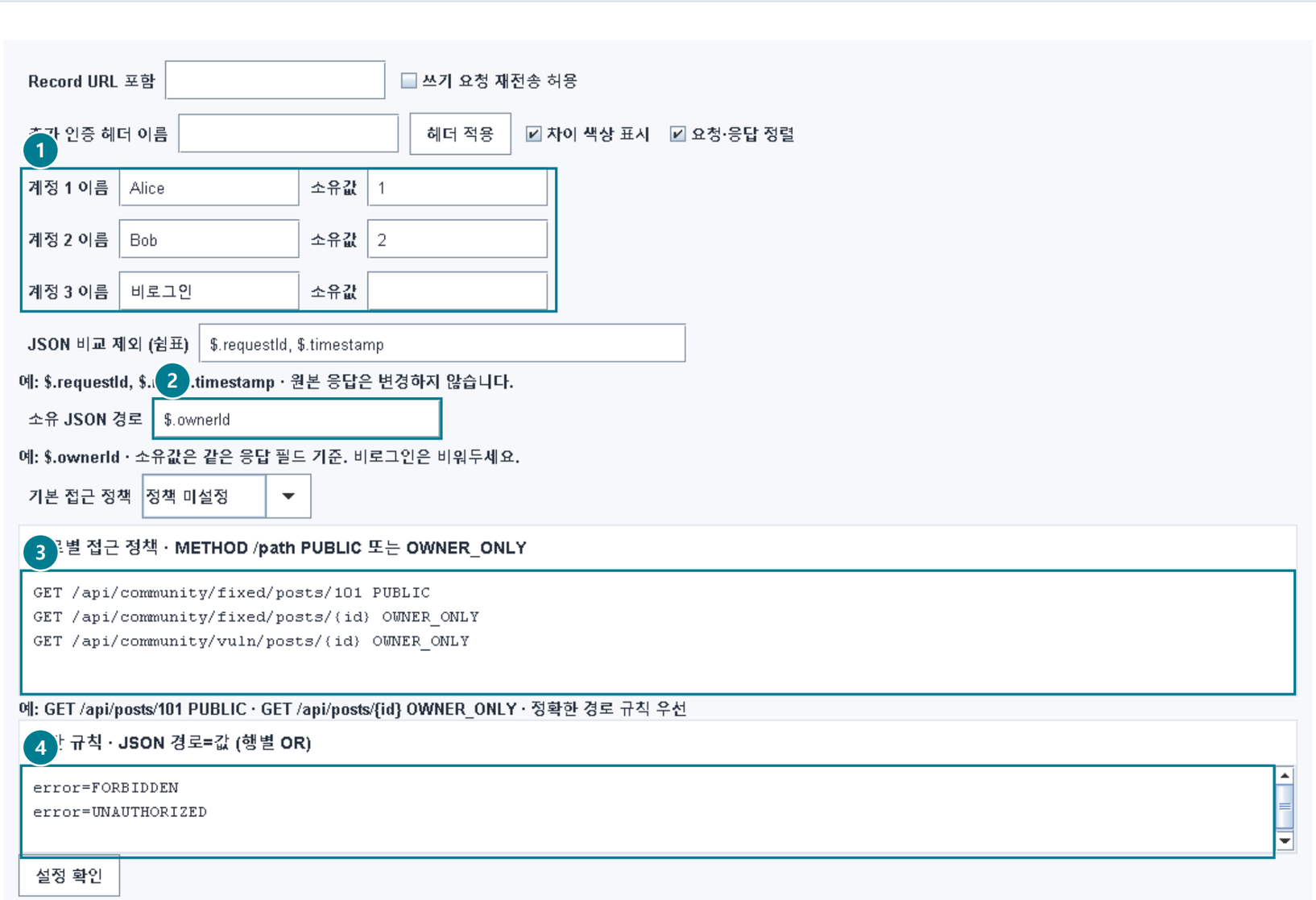
잘못 지정한 계정은 해제한 뒤 올바른 후보로 다시 지정합니다. 로그인 세션이 갱신되면 후보도 다시 확인합니다.

권장 실습 구성: Alice 소유자 1 / Bob 소유자 2 / 비로그인 소유자 공란.

07 인가 정책과 비교 기준 설정

권한 비교 > 비교 설정

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 계정 이름과 소유자 값 입력

Alice=1, Bob=2처럼 응답의 ownerId와 비교할 실제 소유자 값을 넣습니다. 비로그인의 소유자 값은 비웁니다.

2 소유 JSON 경로 지정

예: $.ownerId. JSON 비교 제외에는 $.requestId, $.timestamp처럼 요청마다 달라지는 필드만 넣습니다. 원본 응답은 그대로 보관됩니다.

3 경로별 정책 입력

공개 글은 PUBLIC, 본인만 조회하는 경로는 OWNER_ONLY로 지정합니다. 형식은 GET /api/community/fixed/posts/{id} OWNER_ONLY입니다. 정확한 경로 규칙이 우선합니다.

4 논리적 차단 응답 지정

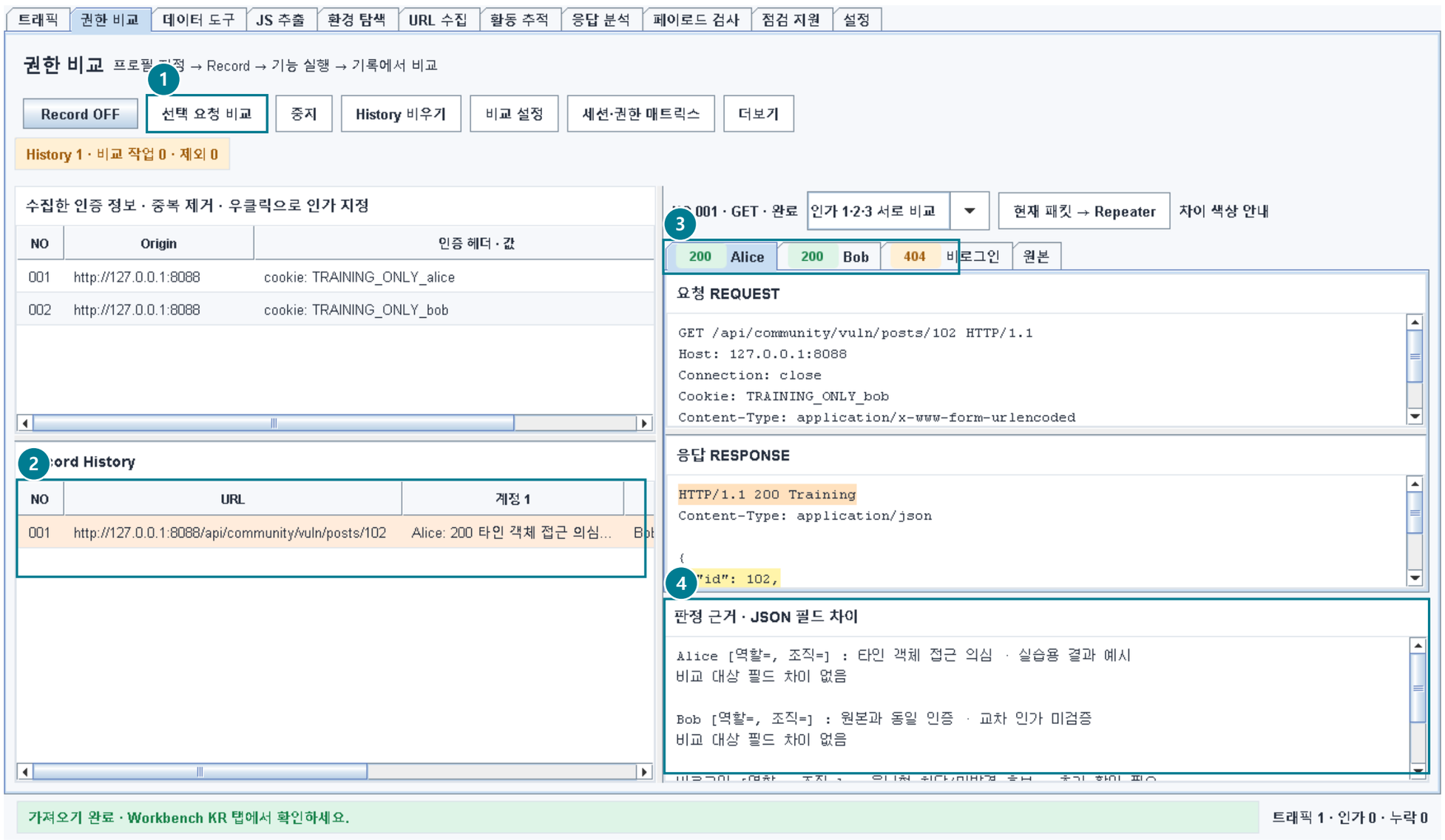
HTTP 200이어도 error=FORBIDDEN 같은 JSON 값이 차단을 뜻할 수 있습니다. 행별 OR 규칙으로 등록하고 설정 확인을 누릅니다.

쓰기 요청 재전송 허용을 켜면 POST 등 상태를 바꾸는 요청도 비교할 수 있습니다. 해당 실습 동작이 필요할 때만 켜세요. 기본 정책 미설정은 공개/소유자 정책을 모른다는 뜻입니다.

08 비교 실행과 결과 읽기

트래픽 선택 > 권한 비교 / 권한 비교 > 선택 요청 비교

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 준비한 계정으로 재전송

계정·정책을 설정한 뒤 트래픽 요청을 선택해 비교합니다. 예: Bob의 비공개 글 102를 Alice, Bob, 비로그인으로 각각 조회합니다.

2 History 결과 선택

비교 작업의 URL, 각 슬롯 상태, 완료 여부를 확인합니다. 행을 선택하면 오른쪽에 해당 작업의 패킷과 판정 근거가 표시됩니다.

3 계정별 패킷 비교

Alice·Bob·비로그인·원본 탭을 번갈아 확인합니다. 원본과 비교 또는 계정끼리 비교 모드로 상태 코드와 응답 내용을 살펴봅니다.

4 판정 근거를 확인하고 재현

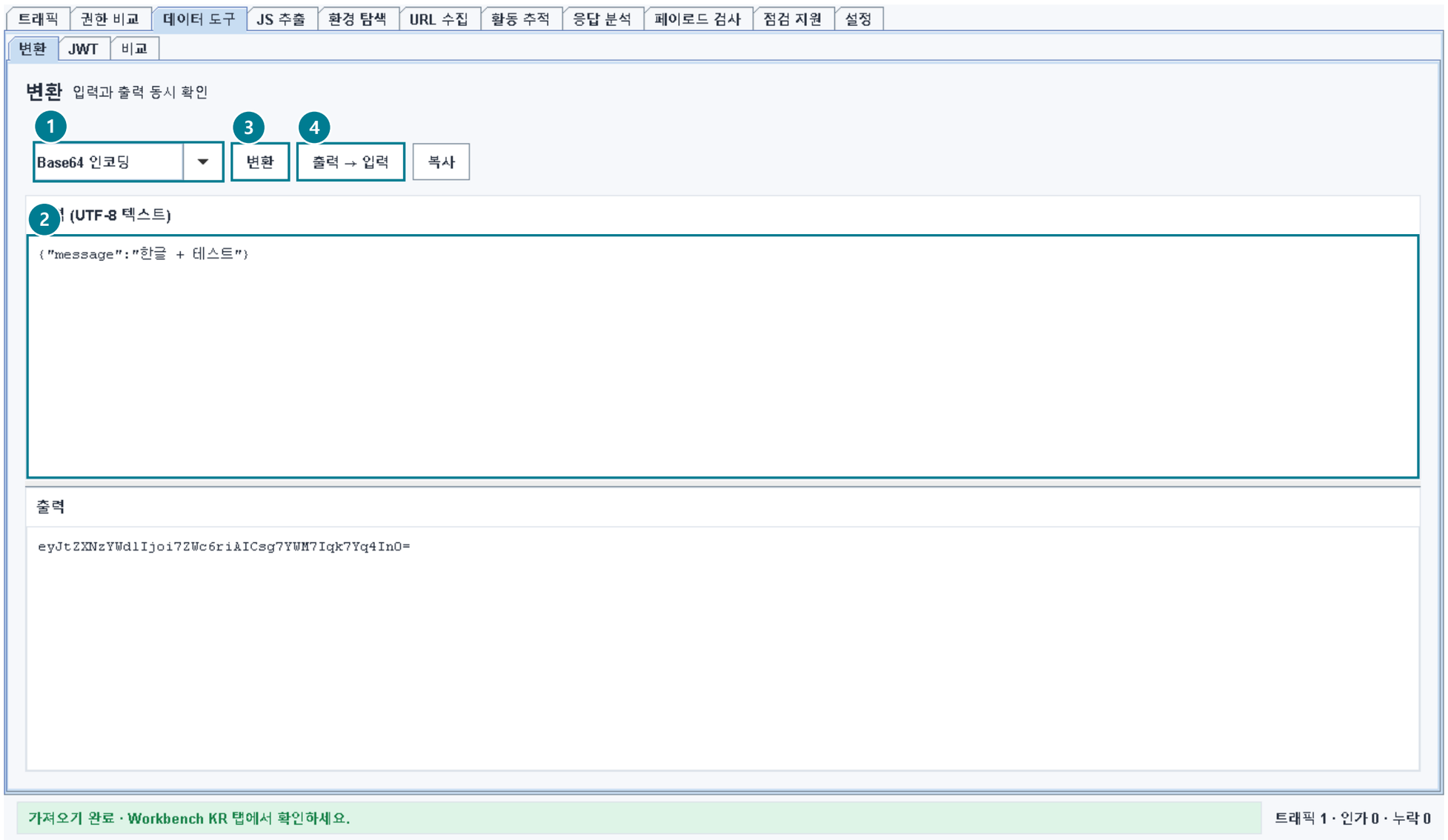
소유자와 정책, 차단 규칙, JSON 차이를 함께 읽습니다. 의심 결과는 현재 패킷 → Repeater로 가져가 직접 재현합니다.

이 페이지의 결과는 설명용으로 채운 예시입니다. PUBLIC 응답의 동일 본문, HTTP 404, 같은 인증끼리의 비교만으로 인가 취약점을 확정하지 않습니다.

09 데이터 변환 사용하기

Workbench KR > 데이터 도구 > 변환

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 변환 종류 선택

URL 인코딩/디코딩, Base64, Hex, 해시 등 필요한 연산을 선택합니다. 그림은 Base64 인코딩 예시입니다.

2 원본 데이터 입력

위쪽 입력 칸에 변환할 값을 붙여 넣습니다. 트래픽 우클릭의 변환 메뉴로도 데이터를 가져올 수 있습니다.

3 변환 실행

변환 버튼을 누른 뒤 아래 출력 칸을 확인합니다. 네트워크 요청 없이 입력 데이터를 처리합니다.

4 연속 변환 또는 복사

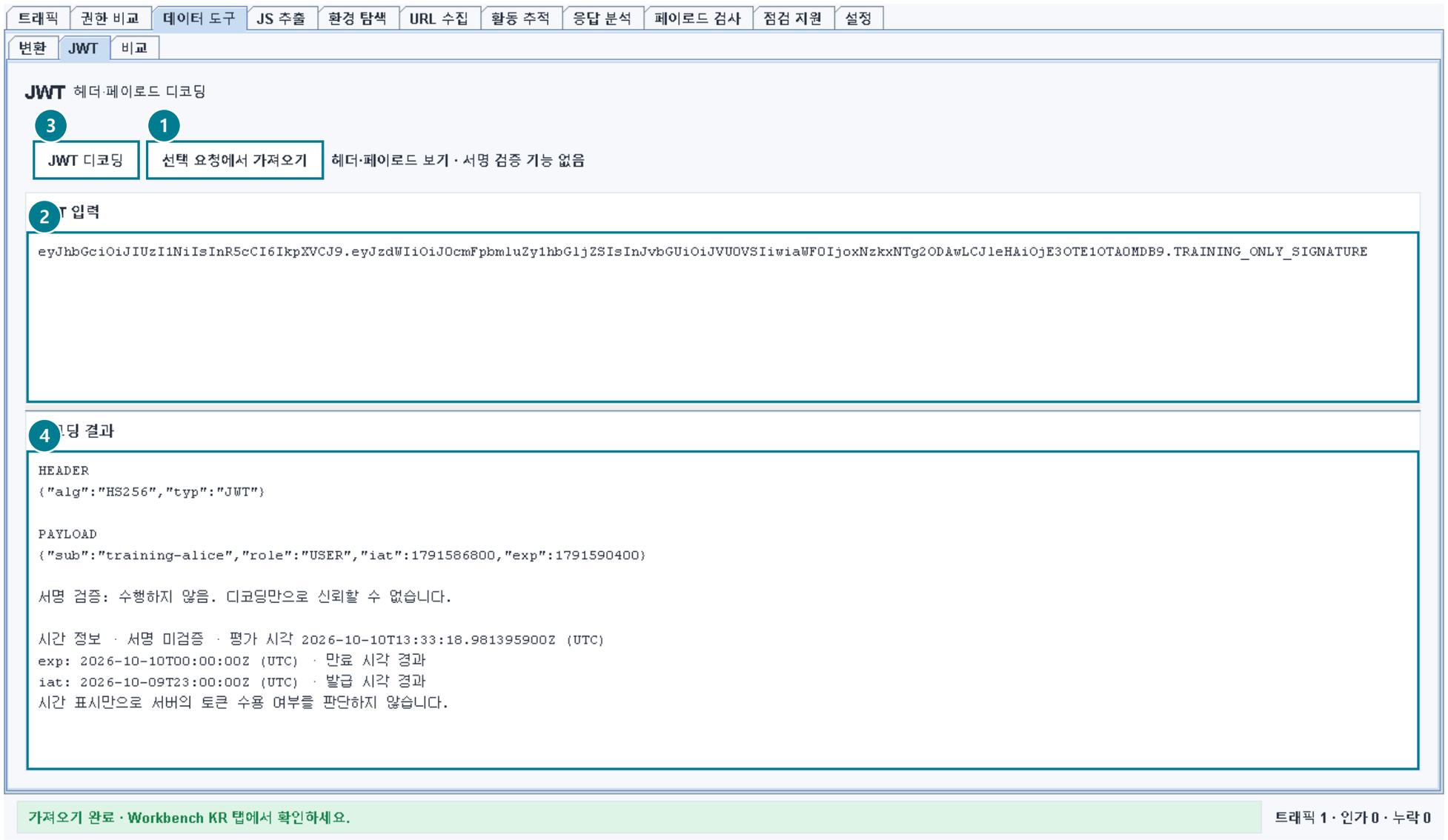
출력을 다시 입력으로 보내 다른 연산을 적용할 수 있습니다. 복사는 현재 출력을 클립보드에 넣습니다.

URL 인코딩의 form 방식은 공백/플러스 처리에 차이가 있습니다. 검사할 파라미터의 인코딩 방식에 맞춰 선택하세요.

10 JWT 내용과 시간 확인하기

데이터 도구 > JWT / 트래픽 우클릭 > JWT

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 선택 요청의 토큰 가져오기

트래픽에서 JWT를 포함한 요청을 선택한 뒤 가져옵니다. 또는 위쪽 입력 칸에 토큰을 직접 붙여 넣습니다.

2 JWT 세 부분 확인

header.payload.signature 형태의 토큰을 넣습니다. 그림의 서명 문자열은 실습용 값입니다.

3 Header와 Payload 디코딩

디코딩을 누르면 alg, typ, sub, role 등 토큰 내용을 출력합니다.

4 iat·nbf·exp 읽기

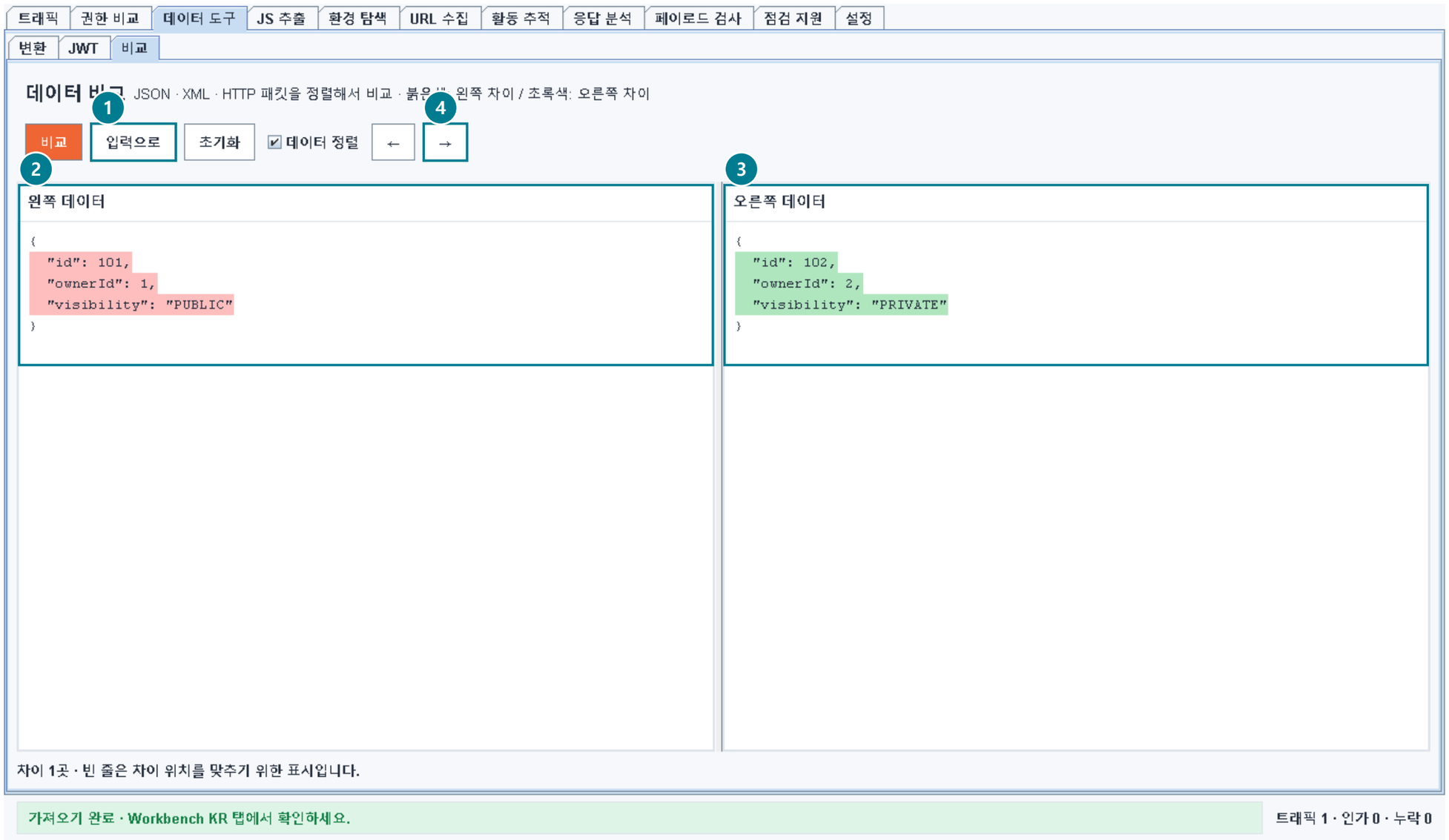
UTC 시간으로 변환된 발급·유효 시작·만료 시각을 확인합니다. 토큰 역할이나 유효 기간이 진단 요구사항에 맞는지 살펴봅니다.

JWT 디코딩은 서명을 검증하지 않습니다. 표시된 role이나 exp만으로 서버의 인증·인가 처리가 올바르다고 판단하지 마세요.

11 JSON·XML·HTTP 데이터 비교

데이터 도구 > 비교

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 두 원본 입력하기

입력 화면에서 왼쪽과 오른쪽에 비교할 JSON, XML 또는 HTTP 데이터를 넣고 비교를 실행합니다. 그림은 비교 결과 화면입니다.

2 왼쪽 차이 확인

왼쪽의 변경 지점이 붉은색으로 표시됩니다. 예시는 id, ownerId, visibility가 서로 다른 응답입니다.

3 오른쪽 대응 값 확인

오른쪽의 대응 지점은 초록색으로 표시됩니다. 정렬한 구조와 원본 문자열을 함께 확인합니다.

4 차이 위치 이동

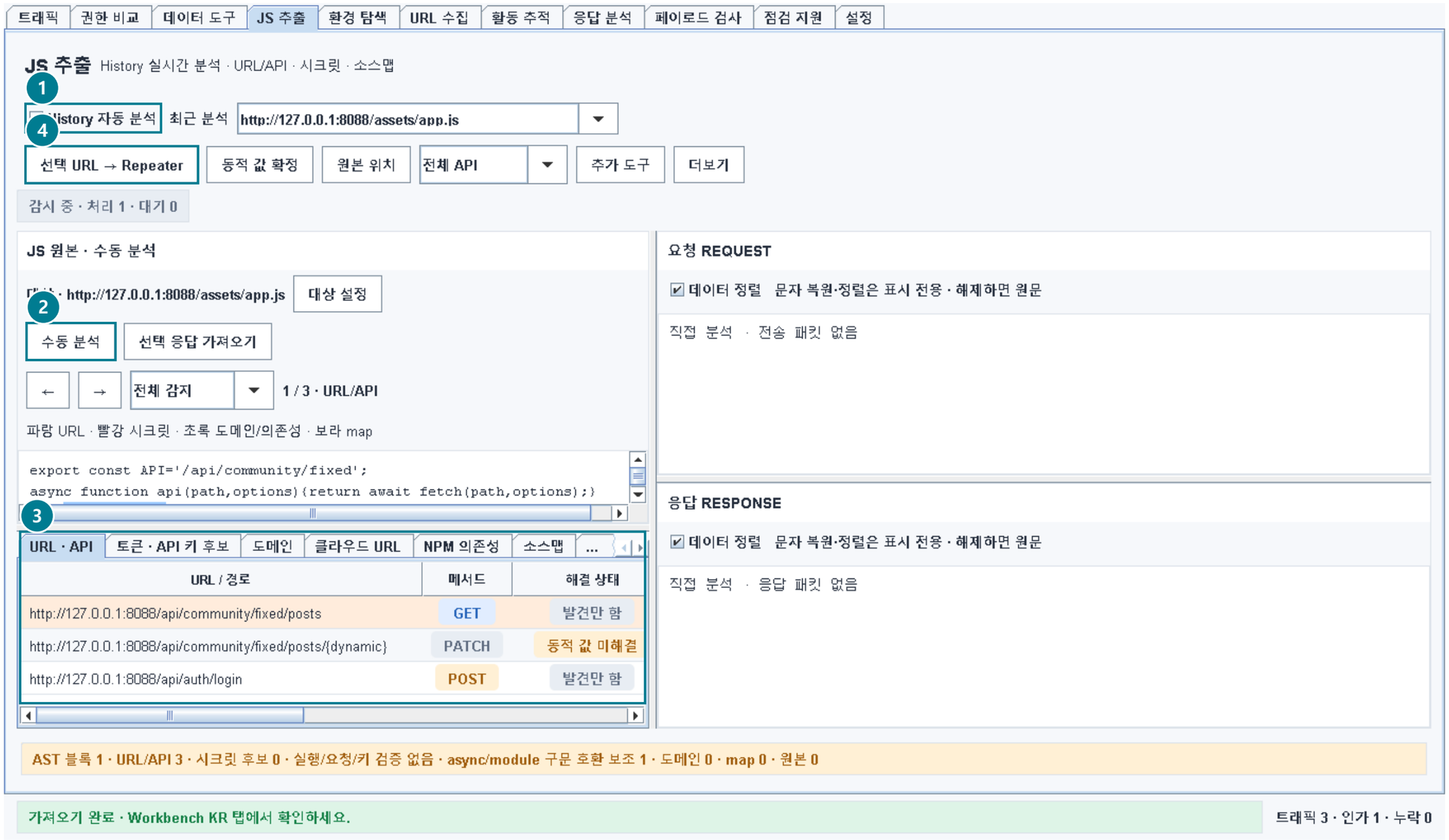
화살표로 이전/다음 차이로 이동합니다. 입력으로 돌아가 값을 바꾸거나 초기화로 새 비교를 시작할 수 있습니다.

구조 정렬과 색상은 읽기 편하게 보여 주는 기능입니다. 원래 패킷 바이트를 수정하거나 요청을 전송하지 않습니다.

12 JS에서 API와 후보 정보 찾기

Workbench KR > JS 추출

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 SCOPE 내 JS 자동 분석

체크하면 Burp History에서 관측한 범위 내 JS를 분석합니다. 최근 분석 목록에서 파일별 결과를 선택할 수 있습니다.

2 직접 분석하기

왼쪽 JS 원본 칸에 소스를 넣고 수동 분석을 누릅니다. 선택 응답 가져오기로 트래픽의 JS 응답을 가져와도 됩니다. 칸이 좁으면 분할선을 내려 넓히세요.

3 URL·메서드·해결 상태 읽기

URL · API 탭에서 GET/POST/PATCH와 발견 근거를 확인합니다. {dynamic}처럼 실제 값이 필요한 결과는 별도로 확정해야 합니다.

4 선택 API 초안 만들기

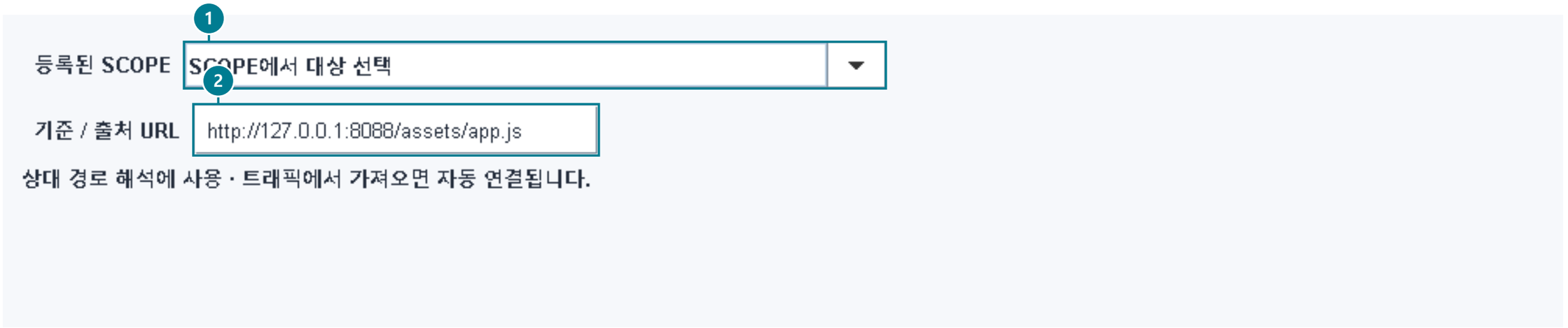
정적인 URL은 메서드와 발견한 파라미터를 바탕으로 Repeater 초안을 만듭니다. REPLACE_ME, 인증, 본문 형식을 확인한 뒤 직접 전송합니다.

다른 결과 탭에는 토큰·API 키 후보, 도메인, 클라우드 URL, NPM 의존성, 소스맵이 있습니다. 분석은 JS를 실행하지 않으며 키 후보의 실제 유효성을 검증하지 않습니다.

13 JS의 기준 URL 설정

JS 추출 > 대상 설정

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 등록한 대상 선택

SCOPE에 등록된 대상 중 기준을 고릅니다. 점검 범위 변경은 트래픽의 SCOPE 목록에서 합니다.

2 분석할 JS 원본 URL 입력

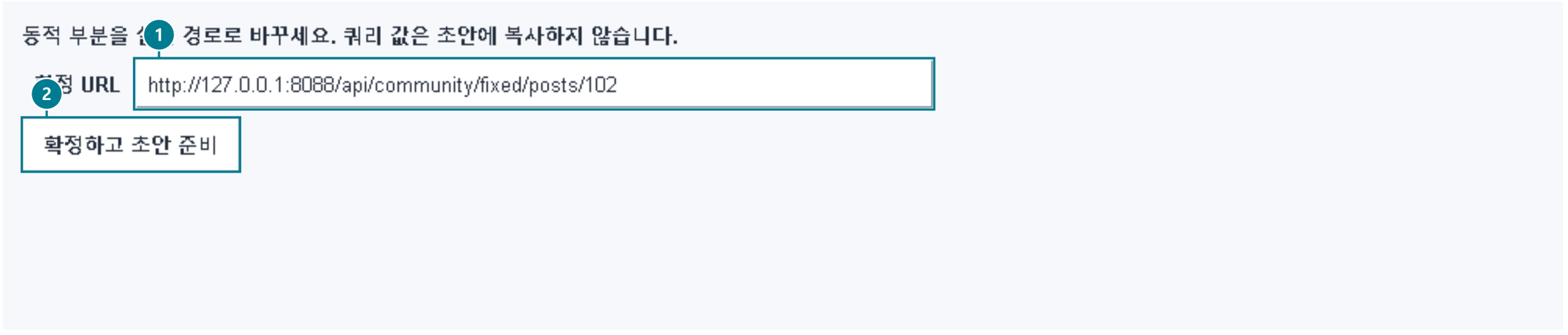
예: http://127.0.0.1:8088/assets/app.js. 상대 경로를 절대 URL로 바꾸는 기준이며 해당 주소를 자동으로 요청하는 버튼이 아닙니다.

URL 입력을 상단에 반복해서 표시하지 않고 대상 설정 창에 모았습니다. 화면의 대상 요약은 현재 분석 기준을 알려 줍니다.

14 동적 URL을 실제 값으로 확정

JS 추출 > 동적 API 행 선택 > 동적 값 확정

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 실제 객체 경로 입력

/posts/{dynamic}의 실제 값이 102라면 http://127.0.0.1:8088/api/community/fixed/posts/102를 입력합니다. 추측한 값은 초안을 보내기 전에 확인합니다.

2 Repeater 초안 준비

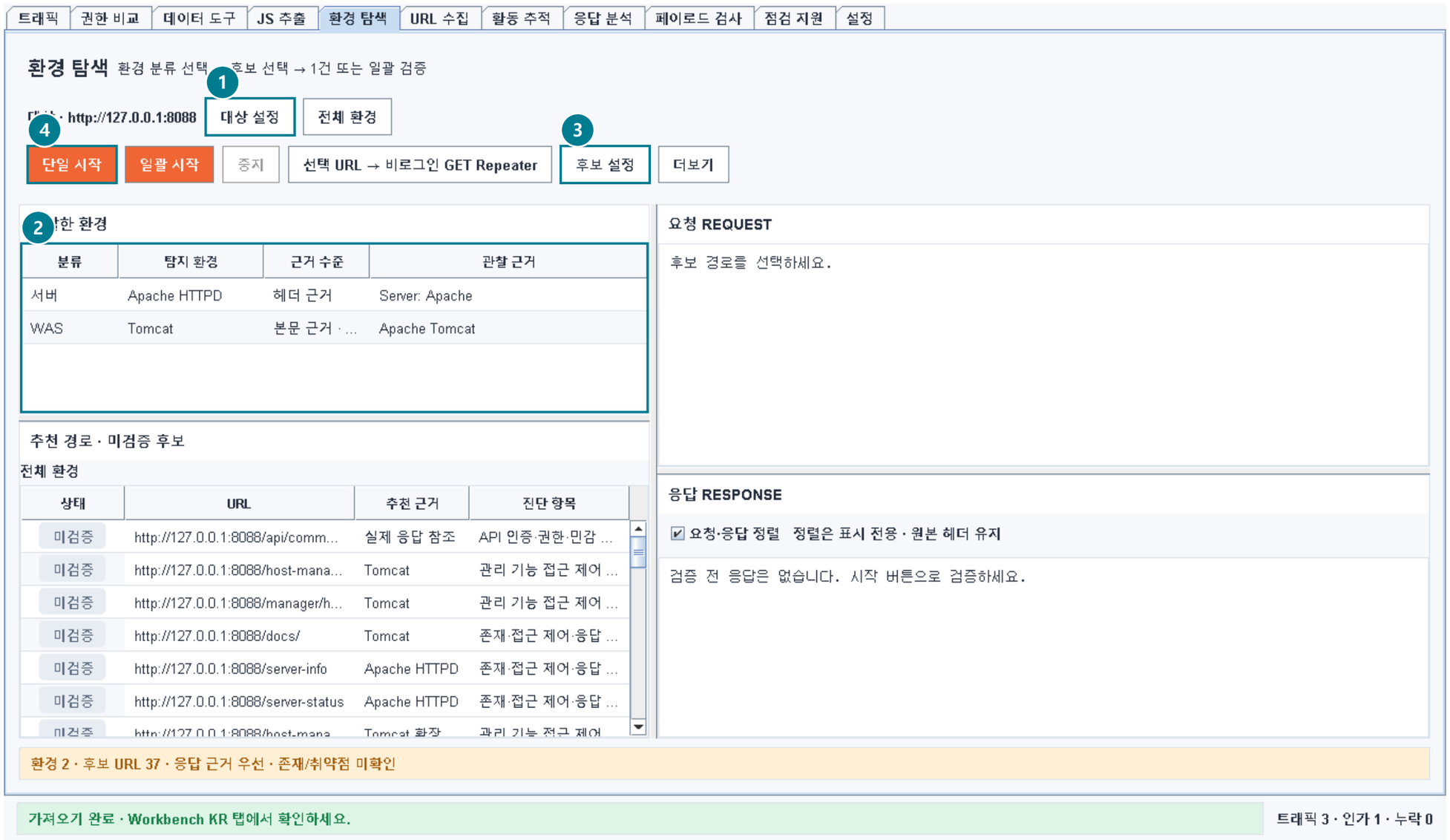
범위 내 URL이면 원래 발견한 메서드를 유지해 초안을 만듭니다. 쿼리 원본 값과 실제 인증은 자동 복사되지 않으므로 Repeater에서 확인합니다.

원본 위치로 JS 근거를 확인할 수 있습니다. 추가 도구의 소스맵 탐색은 명시적으로 GET 요청을 보내고, NPM 존재 조회는 패키지 이름을 지정한 레지스트리에 보냅니다. 수집 파일 저장은 원본 코드를 보관합니다.

15 환경 관찰과 경로 후보 확인

Workbench KR > 환경 탐색

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 범위 내 대상 선택

등록한 SCOPE와 관측된 대상에서 환경 탐색의 대상을 고릅니다. 응답 헤더·오류 페이지로 환경 단서가 모입니다.

2 탐지된 기술 확인

Server 헤더, 오류 문구 등의 근거로 Tomcat 같은 기술 후보를 표시합니다. 제품명이나 버전 단서는 추가 확인이 필요합니다.

3 검증 경로와 기준 설정

경로 접두사, 후보 수, 없는 경로 응답 비교 등을 설정합니다. 다음 페이지의 기준 응답 설정을 확인합니다.

4 선택 후보 또는 전체 검증

단일 시작은 선택 경로, 일괄 시작은 후보 목록을 GET으로 확인합니다. 실제 요청을 전송하며 로그인 Cookie를 자동 상속하지 않습니다.

오른쪽의 요청·응답과 판정 근거를 함께 읽습니다. 선택 URL → 비로그인 GET Repeater로 가져가 응답을 직접 재현할 수 있습니다.

16 없는 경로와 응답 안정성 비교

환경 탐색 > 후보 설정

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 후보 경로 조정

애플리케이션 접두사를 넣고 최대 후보 수를 정합니다. 경로 목록 가져오기로 별도 목록도 사용할 수 있습니다.

2 공통 404·안내 페이지 걸러내기

임의의 없는 경로 응답과 후보 응답을 비교합니다. 모든 URL에 HTTP 200을 반환하는 사이트에서 단순 상태 코드 오판을 줄입니다.

3 기준 응답을 2회 확인

기준 페이지가 반복 요청에도 안정적인지 확인합니다. 불안정한 응답은 같은 페이지라는 근거로 단정하지 않습니다.

4 변동 JSON 필드만 제외

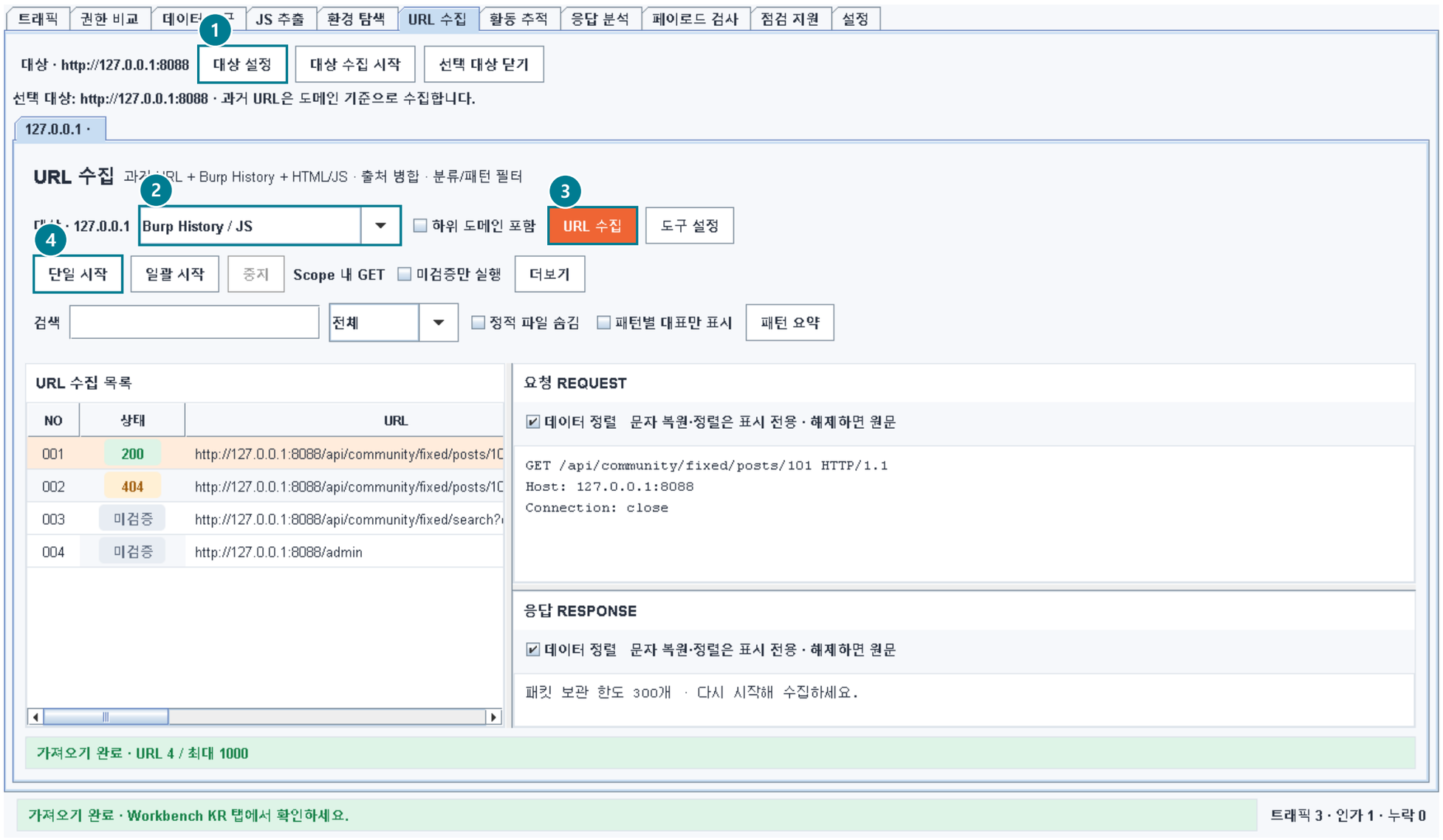
$.requestId, $.timestamp처럼 매 요청 달라지는 필드를 지정합니다. 설정 확인 후 메인 화면에서 시작을 누릅니다.

안정성 확인과 후보 비교도 실제 GET 요청입니다. 일괄 검증은 미검증 후보만 옵션으로 중복 작업을 줄일 수 있습니다.

17 URL 수집과 GET 검증 구분

Workbench KR > URL 수집

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 SCOPE에서 수집 대상 선택

대상을 고른 뒤 대상 수집 시작으로 해당 대상의 작업 화면을 엽니다. 입력 기준은 설정 창에서 관리합니다.

2 수집 출처 선택

처음에는 Burp History / JS를 선택합니다. 관측한 History와 JS에서 발견한 URL을 모으므로 결과에는 미요청 URL도 포함됩니다.

3 URL 수집 실행

URL 수집 버튼으로 목록을 갱신합니다. 더보기에서 기존 URL 목록이나 URL DB를 가져와 이어서 작업할 수 있습니다.

4 필요한 URL만 확인

단일/일괄 시작은 실제 GET 검증입니다. 선택 행의 상태와 패킷을 확인합니다. 수집만 한 URL과 서버에 요청한 URL을 구분합니다.

Wayback 등 다른 출처를 선택하면 외부 서비스 조회가 발생할 수 있습니다. 하위 도메인 포함은 Workbench SCOPE를 자동으로 넓히지 않습니다.

18 URL 패턴과 대표 요청 관리

URL 수집 > 패턴 요약

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 패턴별 미점검 항목 읽기

비슷한 URL을 /posts/{ID}처럼 묶고 신규·변경·미점검 항목과 대표 URL을 표시합니다. 우선순위는 점검 순서이며 취약점 심각도가 아닙니다.

2 대표 요청 수 조정

패턴마다 대표를 최대 5개까지 유지합니다. 상태가 다른 URL도 대표로 남겨 단순 중복 제거로 놓치는 항목을 줄입니다.

3 대표 URL만 먼저 확인

대표 URL 한 건을 GET으로 확인하거나 옆의 Repeater 버튼으로 수동 작업을 준비합니다.

4 DB에 쿼리 값 보관 여부

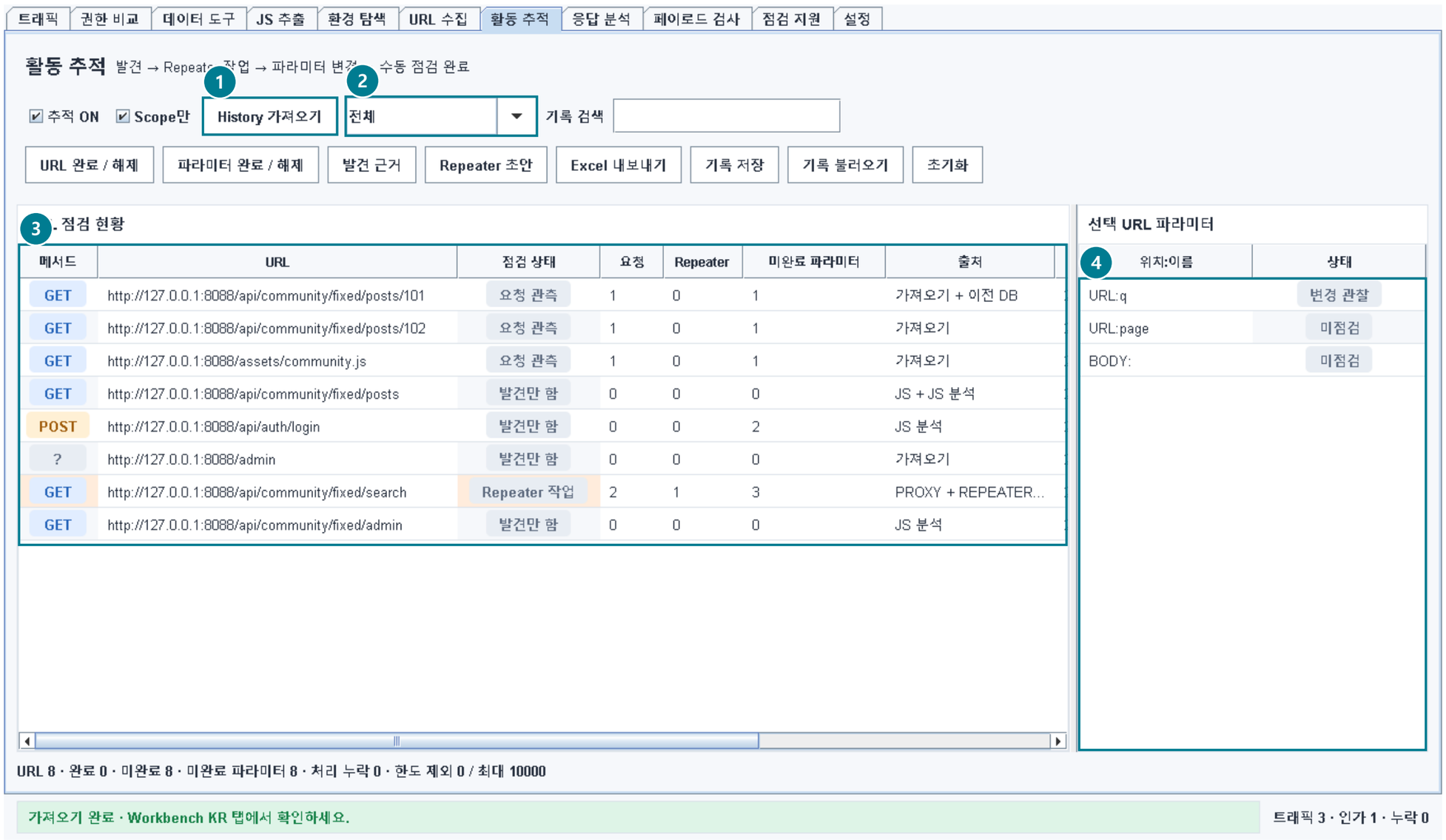
기본적으로 URL DB 저장 시 원본 쿼리 값을 제거합니다. 값을 보관해야 하는 실습에서만 옵션을 켜고 저장 파일을 관리합니다.

메인 화면의 패턴별 대표만 표시·정적 파일 숨김·검색 필터로 목록을 줄일 수 있습니다. 자동 GET 검증에서 상태 변경 위험 경로는 기본적으로 제외됩니다.

19 활동 추적으로 빠진 점검 찾기

Workbench KR > 활동 추적

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 현재 History를 추적에 반영

추적 ON과 Scope만을 확인하고 History 가져오기를 누릅니다. 이후 요청과 JS·URL 수집에서 발견한 경로가 함께 누적됩니다.

2 미점검 항목 필터

미완료 URL·미완료 파라미터·발견만 함·재검토 필요 등을 골라 남은 작업을 확인합니다. 반복 요청 횟수만으로 완료 처리되지 않습니다.

3 URL 상태와 Repeater 작업 읽기

발견만 함은 아직 요청을 보지 못한 URL, 요청 관측은 트래픽을 본 URL입니다. Repeater 열은 해당 도구에서 관측된 요청 수를 보여 줍니다.

4 파라미터 상태 확인

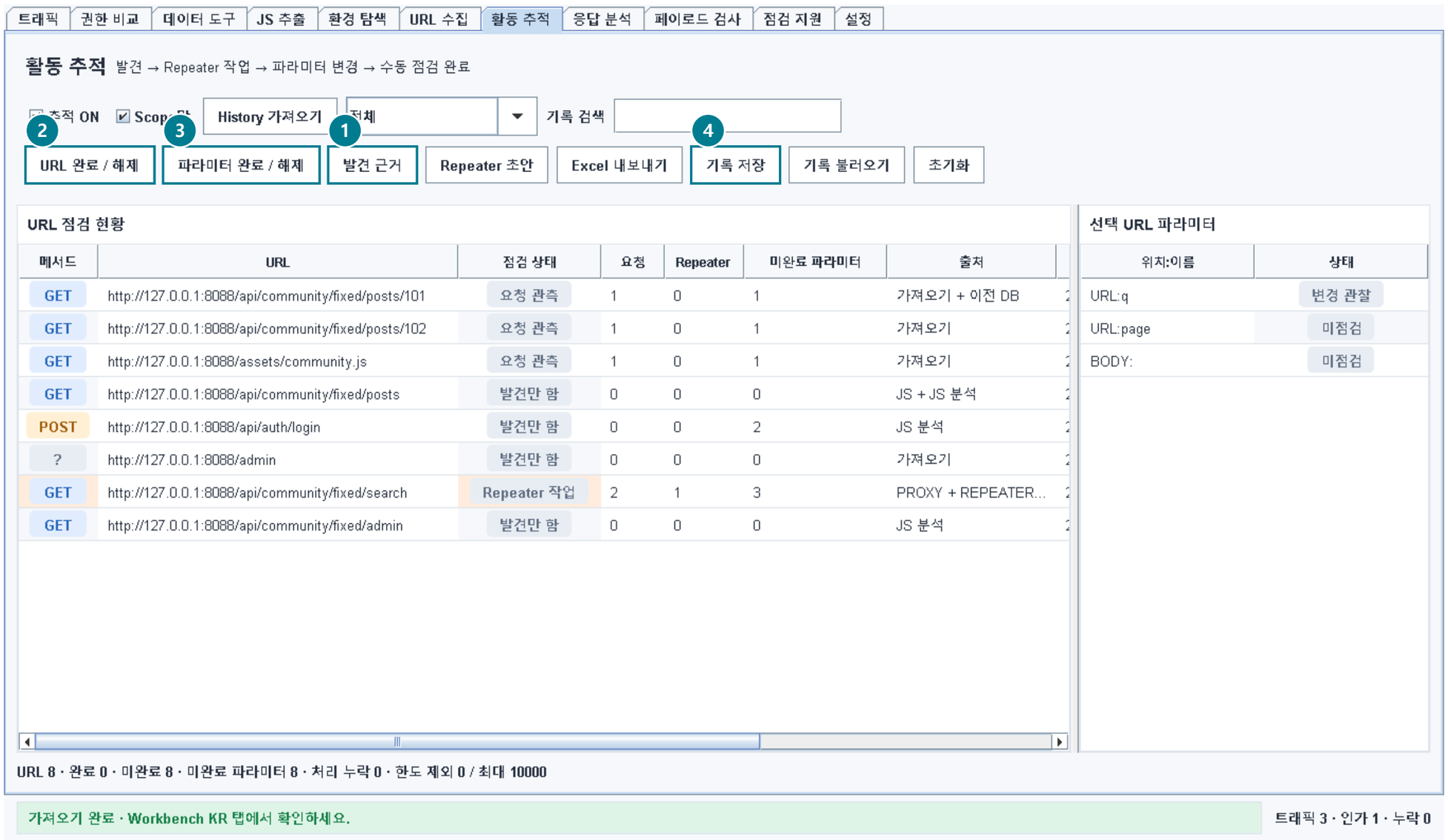
URL 행을 고르면 오른쪽에 URL:q, URL:page 같은 위치:이름과 상태가 나옵니다. 변경 관찰은 값이 달라진 요청을 보았다는 뜻이며 검증 완료가 아닙니다.

JS의 미해결 동적 URL은 실제 경로로 확정한 후 추적과 연결합니다. 발견 항목 수와 수동 점검 완료 수는 서로 다릅니다.

20 수동 완료 처리와 근거 보관

활동 추적 > URL 또는 파라미터 행 선택

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 어디서 발견했는지 확인

선택 URL의 JS 원본·출처·위치 등의 근거를 확인합니다. 아직 요청하지 않은 URL은 Repeater 초안으로 작업을 준비합니다.

2 URL 단위 점검 완료

실제 검증을 끝낸 URL을 선택해 완료 처리합니다. 잘못 완료한 경우 같은 버튼으로 해제할 수 있습니다.

3 파라미터별 완료 처리

오른쪽의 개별 파라미터를 선택해 완료 처리합니다. URL 완료와 파라미터 완료는 별도 상태이므로 각각 확인해야 합니다.

4 결과와 진행 상태 보관

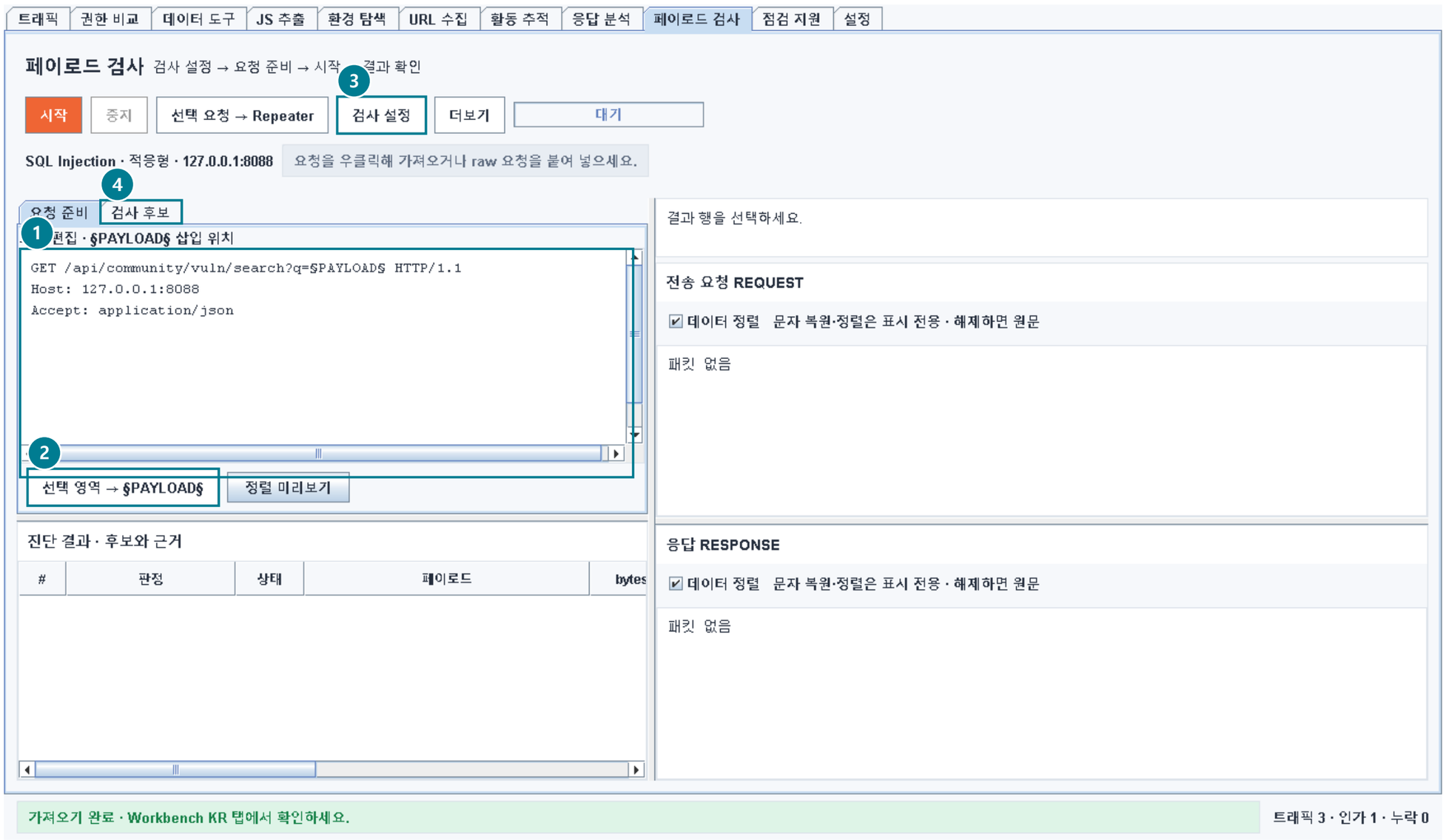
기록 저장/불러오기로 점검을 이어가고 Excel 내보내기로 남은 URL·파라미터를 공유합니다. 초기화 전 필요한 기록을 저장합니다.

실습 순서: q=Burp 요청 관측 > Repeater에서 q=security로 변경 > 변경 관찰 확인 > 결과를 직접 판단 > URL과 필요한 파라미터를 수동 완료. Repeater 초안 준비만으로 완료되지는 않습니다.

21 페이로드 검사 요청 준비

트래픽 우클릭 > 페이로드 검사

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 실제 요청을 가져와 편집

원래 동작하는 HTTP/1 요청을 가져옵니다. 예시는 실습용 검색 API입니다. Host, Cookie, 본문 형식과 대상이 맞는지 확인합니다.

2 교체할 값 하나 지정

q=Burp에서 Burp 부분을 선택하고 버튼을 누릅니다. 요청에는 §PAYLOAD§가 정확히 한 곳 있어야 합니다.

3 검사 유형과 제한 확인

대상 주소·포트, 검사 유형, 인코딩, 기준값, 요청 한도와 대기시간을 설정합니다. 이 단계에서는 요청을 보내지 않습니다.

4 보낼 후보 목록 확인

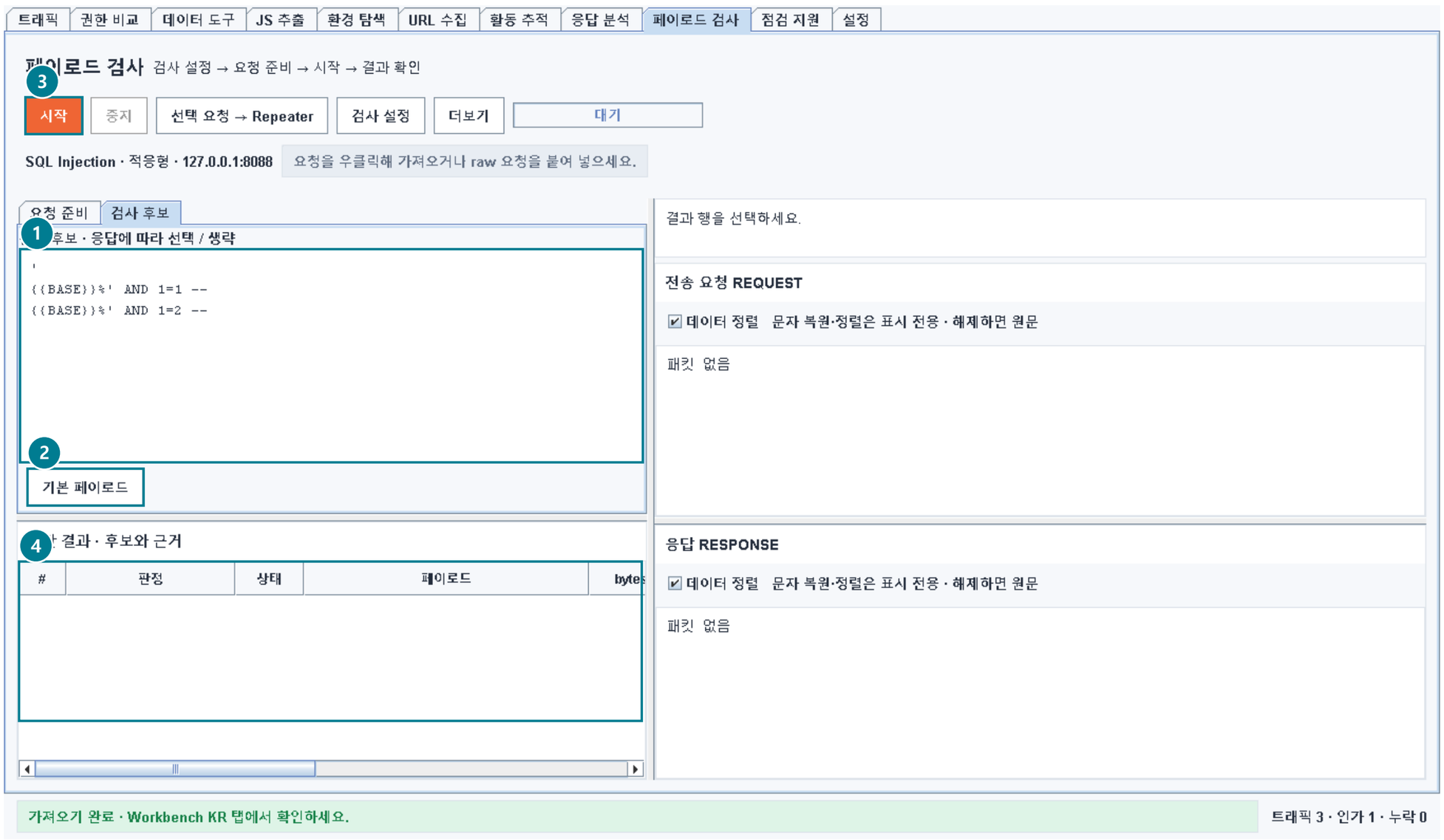
검사 후보 탭에서 목록을 검토합니다. 처음에는 대상에 맞는 적은 수의 후보로 실습한 뒤 시작을 누릅니다.

압축 또는 chunked 요청 본문은 먼저 수동으로 정상화해야 합니다. 요청 편집 화면의 정렬 미리보기는 읽기용이며 원본 편집과 구분됩니다.

22 검사 후보 편집과 실행

페이로드 검사 > 검사 후보

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 한 줄에 후보 하나 입력

기본 후보를 검토하거나 필요한 항목만 남깁니다. {{BASE}}는 기준값, {{MARKER}}는 검사 마커로 치환됩니다.

2 유형별 기본 목록 복원

선택 검사 유형의 기본 목록을 다시 불러옵니다. 편집한 목록을 덮어쓰므로 필요한 사용자 후보는 먼저 보관합니다.

3 실제 검사 시작

시작을 누르면 기준·대조·후보 요청이 전송됩니다. 적응형 모드는 응답에 따라 후보를 선택하거나 생략하고 순차 모드는 목록 순서로 실행합니다.

4 판정과 근거 확인

결과 행을 선택하면 오른쪽에서 전송 요청, 응답, 판정 근거를 확인합니다. 선택 요청 → Repeater로 재현하고 더보기에서 CSV를 저장합니다.

중지는 후속 요청을 멈춥니다. 이미 보낸 요청은 응답 또는 대기시간까지 기다릴 수 있습니다. 후보 수와 실제 요청 수는 기준·반복 검증 때문에 다를 수 있습니다.

23 검사 설정 창 사용하기

페이로드 검사 > 검사 설정

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 대상과 SCOPE 확인

프로토콜·호스트·포트를 확인하고 범위 제한을 유지합니다. 화면에는 Burp Scope 내 요청만으로 표시되지만 통합 확장에서는 Workbench SCOPE 판정이 연결됩니다.

2 검사 유형과 인코딩 선택

SQL Injection 등 16개 유형 중 대상에 맞는 유형을 고릅니다. 쿼리 값은 URL, JSON 값은 JSON 등 삽입 위치에 맞는 인코딩을 확인합니다.

3 원래 정상 값 설정

예: 검색어 Burp. 이 값으로 정상 응답을 얻고 대조합니다. 적응형/순차 모드와 요청 간격도 함께 확인합니다.

4 총 요청 수와 대기시간 제한

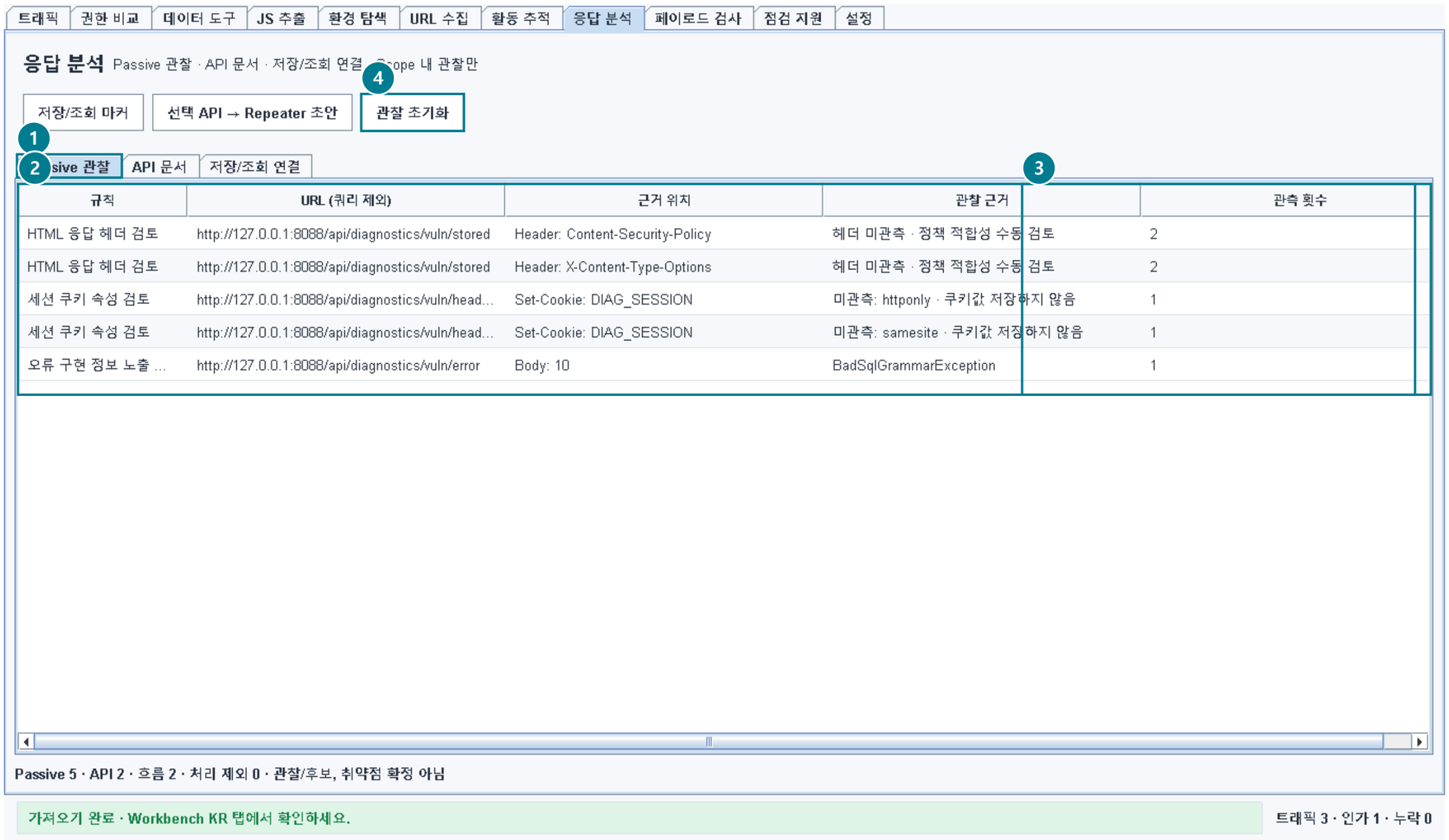
예시는 간격 250ms, 총 한도 100, 대기 10초입니다. 기준·대조 요청도 한도에 포함됩니다. 401/403/429/503 또는 시간 초과 시 중단 사유를 확인합니다.

유형: XSS, SQLI, UPLOAD_NAME, UPLOAD_BODY, DOWNLOAD, SSTI, TRAVERSAL, REDIRECT, CRLF, XXE, XPATH, LDAP, NOSQL, SSRF, COMMAND, CUSTOM. 업로드 재조회와 SSRF 콜백은 해당 실습의 명시적 검증 옵션입니다.

24 Passive 응답 관찰 읽기

Workbench KR > 응답 분석 > Passive 관찰

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 관찰 화면 열기

SCOPE 내 응답을 받아 헤더, Cookie 속성, 오류·정보 노출 단서를 분석합니다. 관찰 자체는 추가 HTTP 요청을 보내지 않습니다.

2 관찰 유형과 URL 확인

예시는 보안 헤더 누락, Cookie 속성 누락, 오류 종류 단서입니다. 횟수와 근거를 함께 확인해 반복 발견과 새 항목을 구분합니다.

3 근거와 적용 맥락 확인

HTML 페이지인지 API인지, Cookie의 용도와 적용 범위가 무엇인지 직접 확인합니다. 후보 경고를 그대로 확정 취약점으로 보고하지 않습니다.

4 새 점검 구간 시작

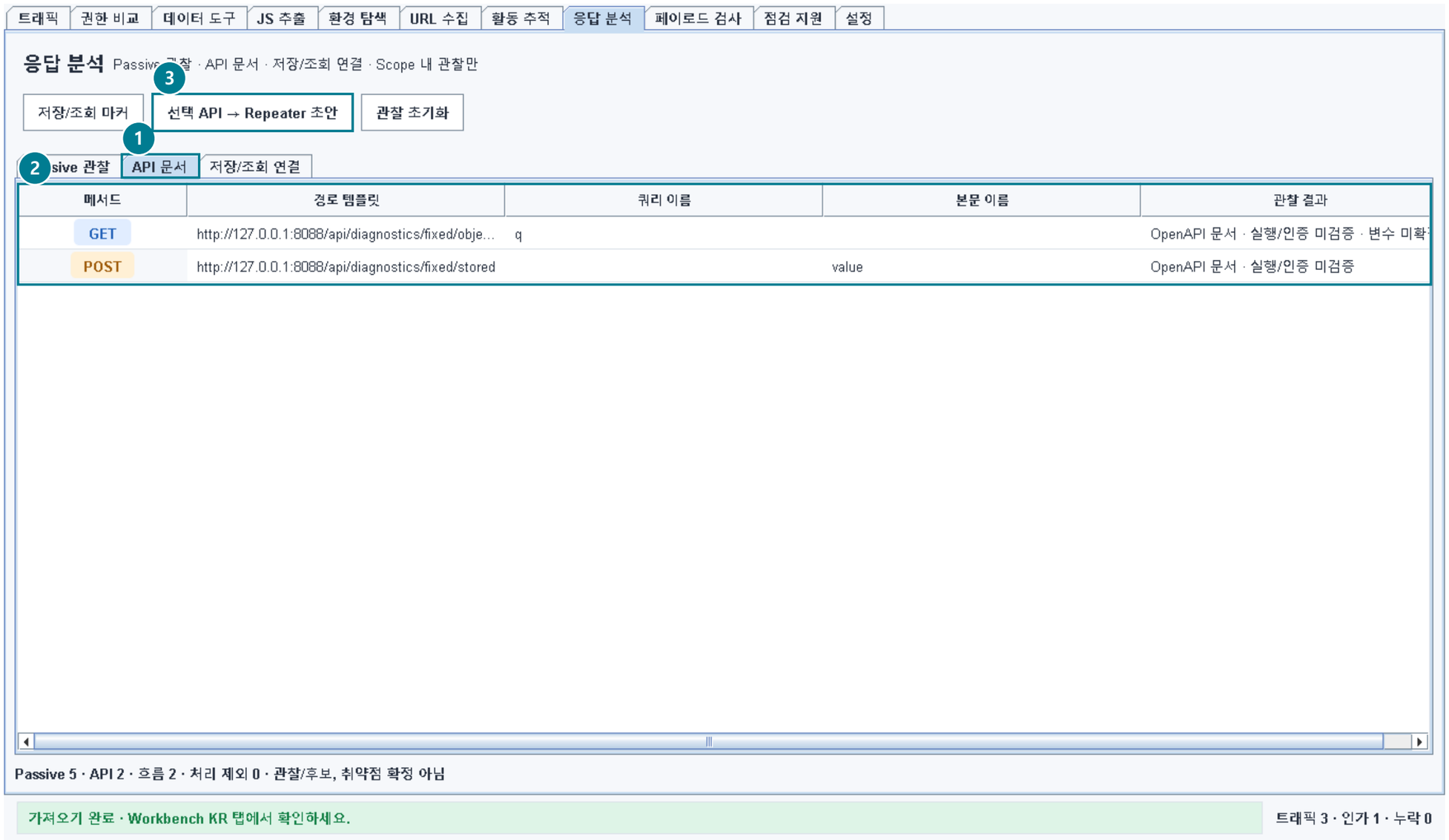
현재 관찰 목록을 비웁니다. 이 응답 분석 작업 공간의 누적 관찰이 초기화되므로 필요한 근거를 먼저 보관합니다.

Passive 관찰, API 문서, 저장/조회 연결은 응답 분석 안의 하위 탭입니다. 예시의 오류 문구는 진단 실습용 데이터입니다.

25 OpenAPI에서 요청 초안 만들기

응답 분석 > API 문서

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 관측한 문서 결과 확인

브라우저로 OpenAPI JSON을 조회해 해당 응답이 Burp를 지나도록 합니다. 범위 내 문서가 관측되면 API 목록이 채워집니다.

2 메서드·경로·입력 위치 읽기

GET과 POST를 보존하며 경로 변수와 쿼리·본문 키를 표시합니다. 템플릿 {id}는 실제 경로로 확정해야 합니다.

3 선택 API의 초안 준비

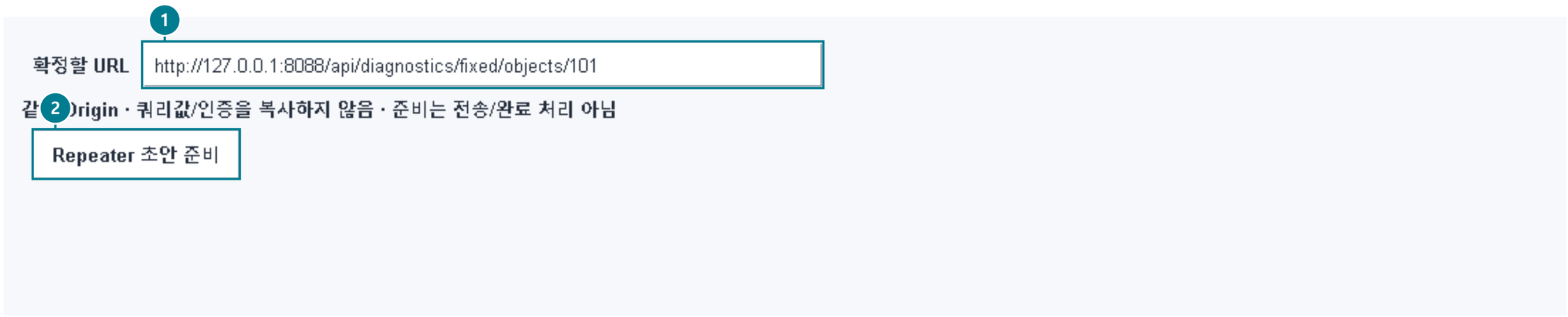
API 행을 선택하고 버튼을 누릅니다. 템플릿이면 확정 URL 창이 열립니다. 다음 페이지에서 객체 값을 넣습니다.

문서에 있는 API는 서버에서 요청 성공이 확인된 URL과 다릅니다. POST API를 임의의 GET 요청으로 바꾸지 않습니다.

26 API 템플릿 경로 확정

API 문서 > 선택 API → Repeater 초안

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 실제 {id} 값 입력

예: /api/diagnostics/fixed/objects/{id}를 /api/diagnostics/fixed/objects/101로 바꿉니다. 확정한 경로는 같은 Origin과 SCOPE 내에 있어야 합니다.

2 값과 인증을 직접 확인

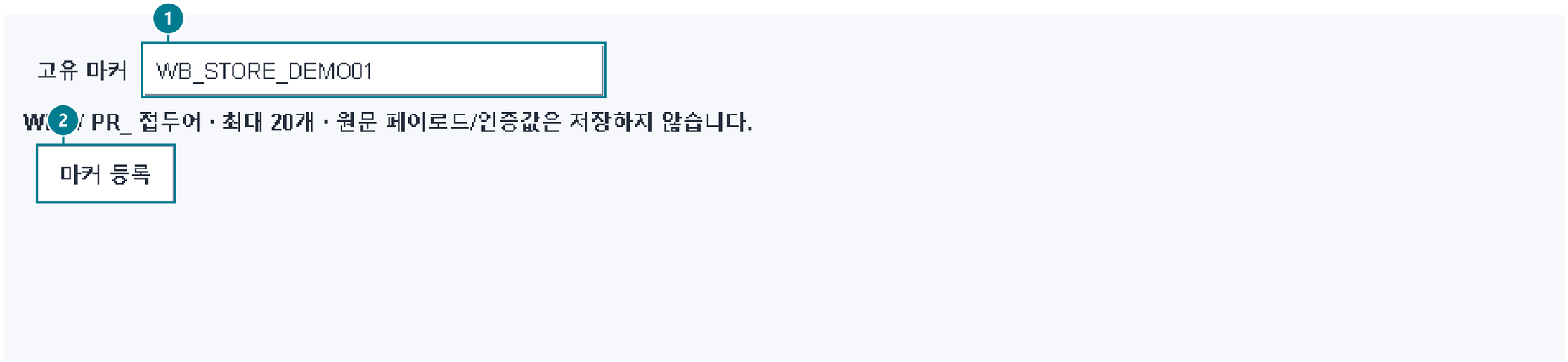
초안을 Repeater로 보낸 뒤 REPLACE_ME 파라미터, 인증, 본문을 확인합니다. 준비 버튼 자체는 서버로 요청을 전송하지 않습니다.

OpenAPI는 필요한 입력 구조를 찾는 출처입니다. 실제 권한 정책과 필수 파라미터 값은 사이트 동작 및 응답으로 확인하세요.

27 저장/조회 검증용 마커 등록

응답 분석 > 저장/조회 마커

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 고유한 실습 마커 입력

WB_STORE_DEMO01처럼 WB_ 또는 PR_ 접두사의 마커를 입력합니다. 다른 점검과 섞이지 않도록 고유한 값을 사용합니다.

2 이후 쓰기와 읽기를 연결

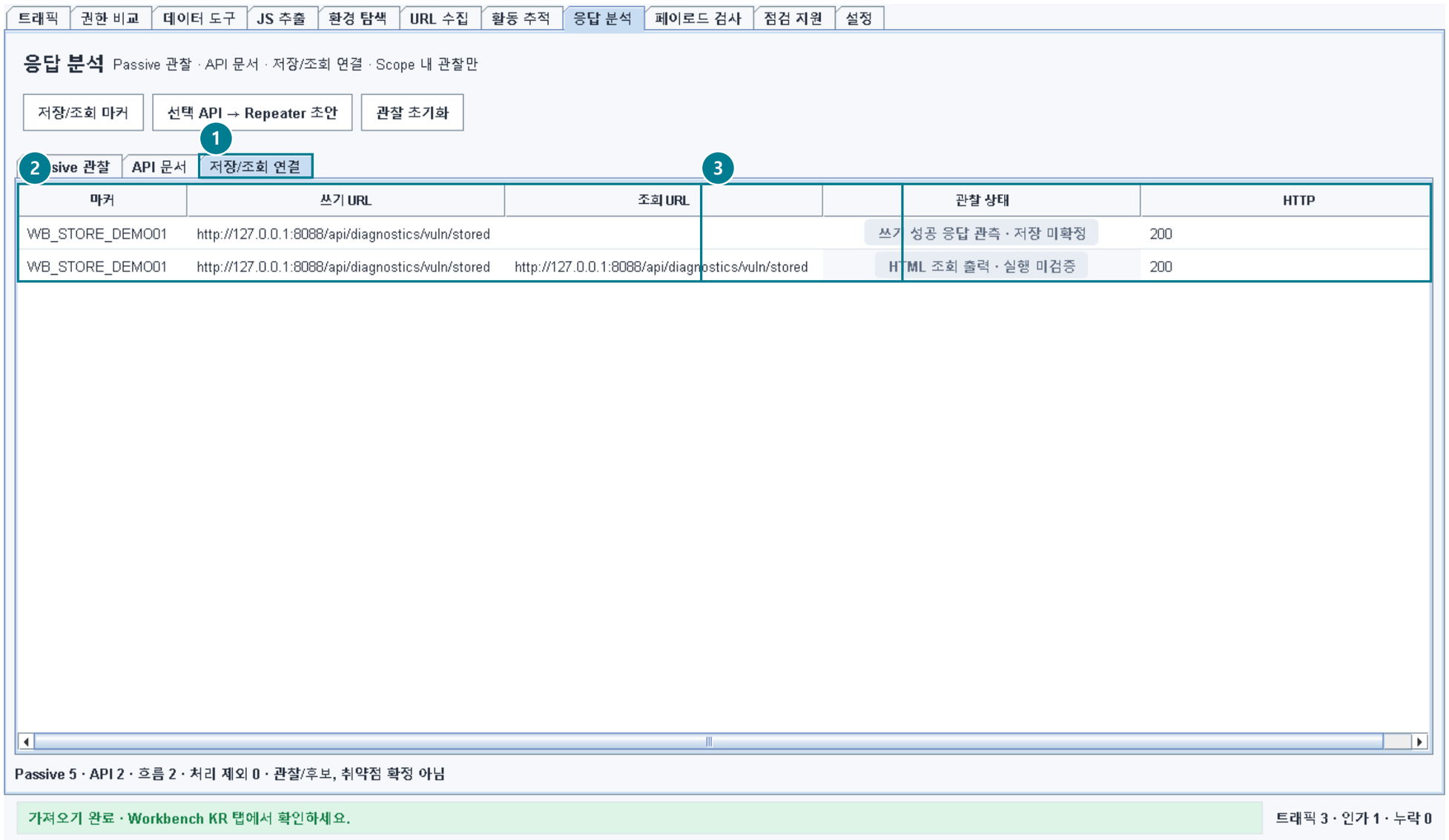
등록 후 Repeater에서 마커를 포함한 저장 요청을 보내고 같은 대상의 조회 요청을 보냅니다. 마커 등록만으로 요청이 전송되지는 않습니다.

최대 20개를 등록하며 원본 마커는 저장 파일이나 인증 후보로 저장되지 않습니다. 실습 요청 예: value=WB_STORE_DEMO01를 저장한 뒤 다시 조회.

28 저장 결과가 조회에 나타나는지 확인

응답 분석 > 저장/조회 연결

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 연결 결과 탭 열기

등록 마커가 쓰기 요청과 이후 같은 Origin의 조회 응답에서 관측되면 연결 결과가 표시됩니다.

2 쓰기·조회 URL 짝 확인

어떤 저장 요청의 값이 어느 조회 응답에서 나타났는지 확인합니다. HTTP 상태와 관찰 근거도 함께 읽습니다.

3 출력 형태의 차이 읽기

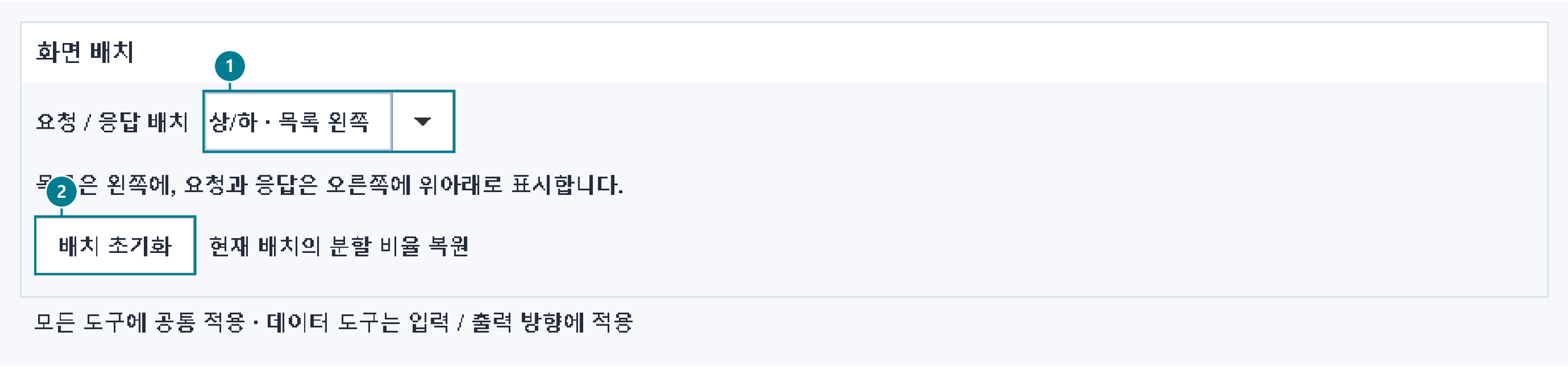
HTML 원문 출력, 이스케이프된 문자 출력 등 표시 맥락을 구분합니다. 실습용 vuln과 fixed 경로를 비교하면 저장 후 출력 처리의 차이를 볼 수 있습니다.

마커가 다시 나타난다는 사실만으로 저장형 XSS 실행을 증명하지는 않습니다. 브라우저 맥락과 실제 출력 처리까지 확인해야 합니다.

29 설정은 현재 화면을 유지한 채 열기

Workbench KR > 설정

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 요청·응답 방향 변경

상/하는 목록을 왼쪽에 두고 요청·응답을 위아래로 표시합니다. 좌/우는 목록을 위에 두고 패킷을 아래에 나란히 표시합니다.

2 분할 비율 복원

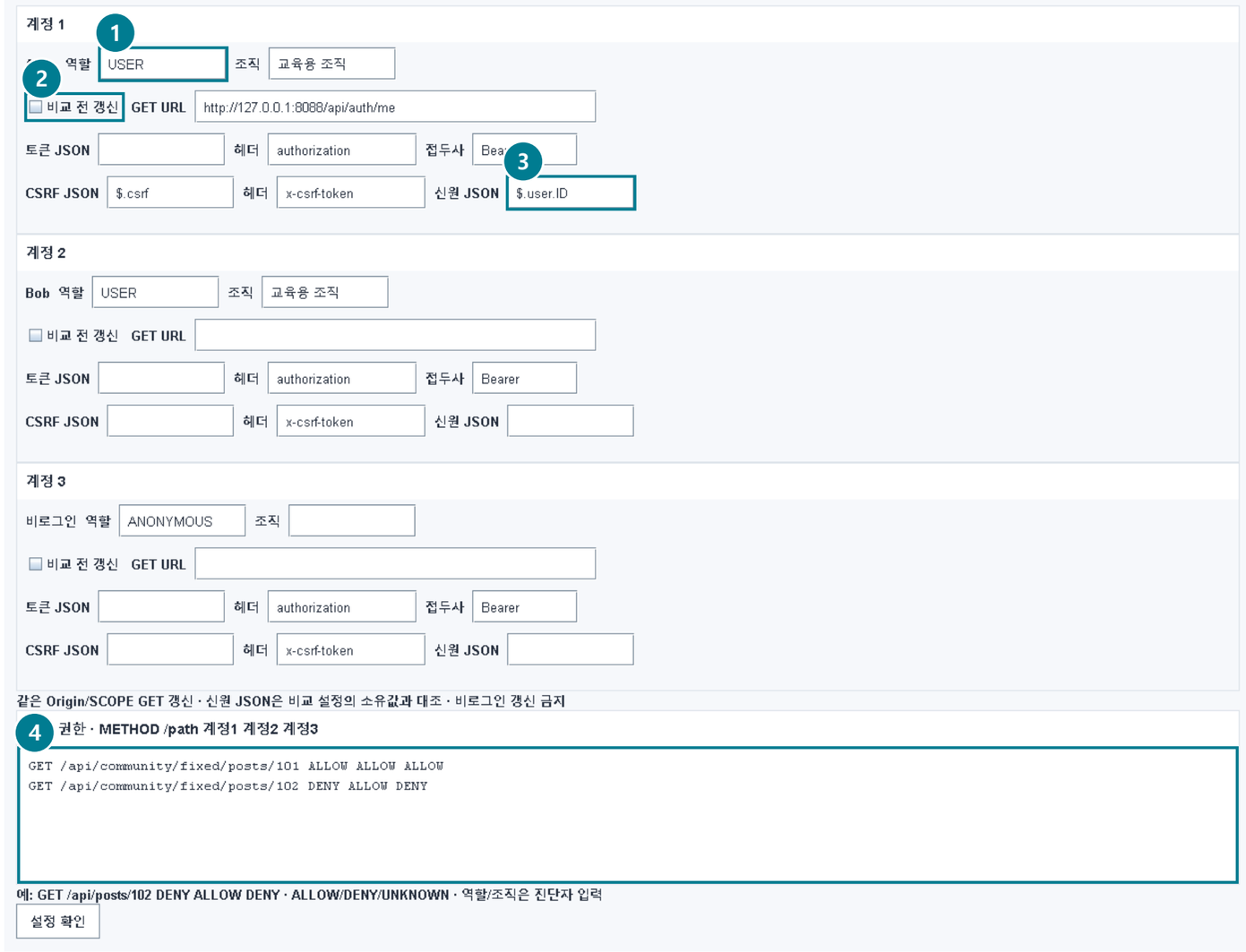
너무 좁아진 영역을 기본 분할 비율로 되돌립니다. 선택한 상/하 또는 좌/우 방향은 유지합니다.

설정 탭은 별도 창을 여는 동작입니다. 기존 작업 탭과 선택 상태를 유지하며, 공통 배치는 데이터 도구의 입력/출력에도 적용됩니다. 설정 창을 닫고 원래 작업을 이어가세요.

30 계정 세션과 기대 권한 설정

권한 비교 > 세션·권한 매트릭스

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 역할·조직 기록

계정별 실제 역할과 조직을 기록합니다. 이름은 진단자가 입력하는 설명이며 서버 정책을 자동 추론하지 않습니다.

2 계정별 GET 갱신 선택

인증 후보를 지정한 계정만 갱신할 수 있습니다. 같은 Origin/SCOPE의 GET URL을 지정합니다. 기본은 꺼짐이며 실패하면 해당 비교 요청을 보내지 않습니다.

3 신원과 갱신 값 확인

토큰·CSRF JSON 경로와 목적 헤더를 설정합니다. 신원 JSON은 비교 설정의 소유값과 대조합니다. 복잡한 로그인은 Burp 세션 규칙/매크로로 준비합니다.

4 기대 권한 직접 지정

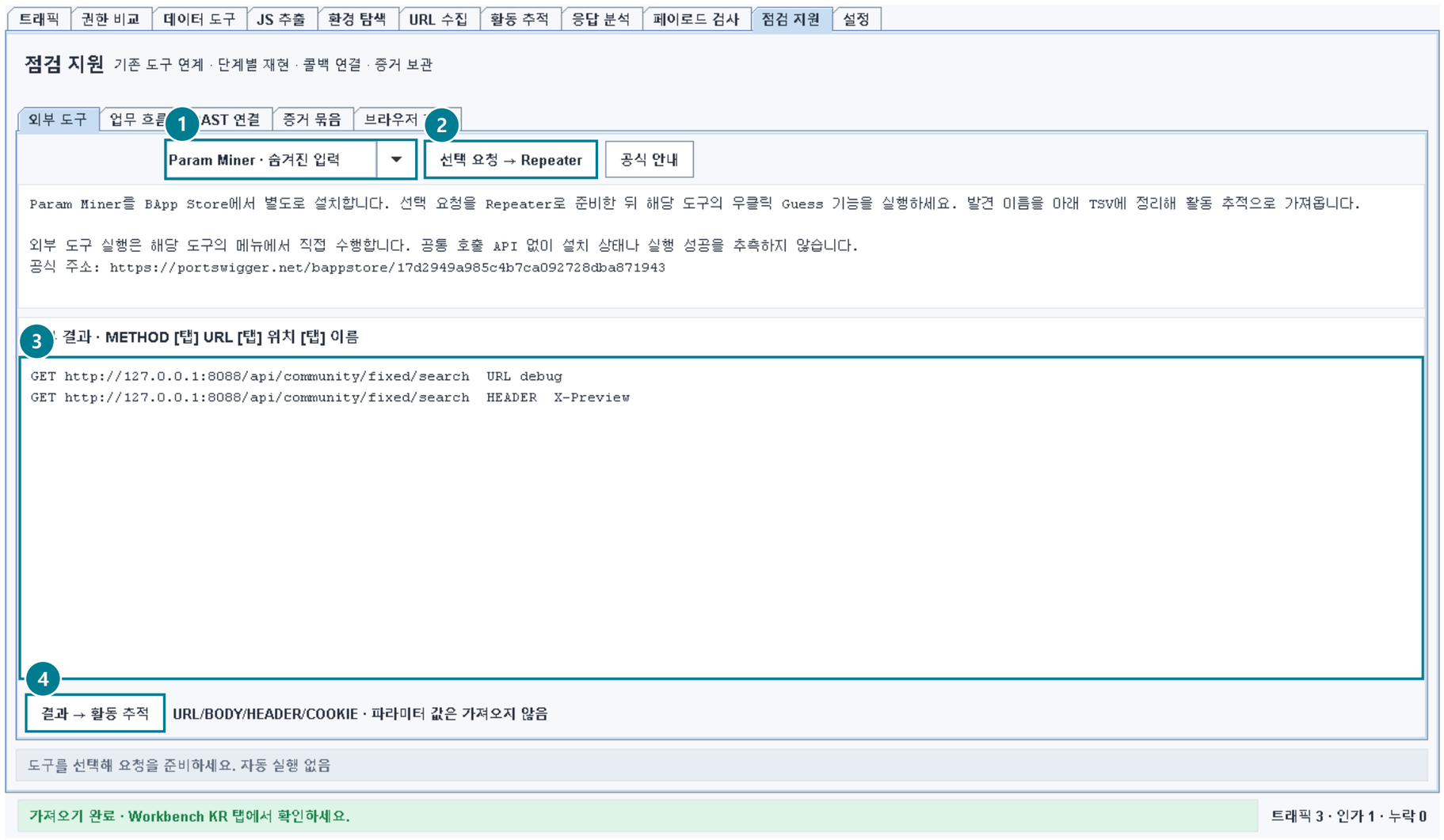
METHOD /path 계정1 계정2 계정3 형식으로 ALLOW/DENY/UNKNOWN을 입력합니다. 그림의 공개 101과 Bob 비공개 102는 교육용 예입니다. 설정 확인 후 다음 비교부터 적용됩니다.

경로의 {id} 템플릿보다 정확한 경로 규칙이 우선합니다. 404·빈 응답·세션 오류는 검토 대상이고 DENY에서 데이터가 반환되어도 후보로 재현해야 합니다. 조직 이름만으로 조직 간 권한이 검증되지는 않습니다.

31 기존 도구로 검사하고 발견 이름 연결

점검 지원 > 외부 도구

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 상황에 맞는 도구 선택

Param Miner는 숨겨진 입력, InQL은 GraphQL, Turbo Intruder는 동시성 검사에 활용합니다. 복잡한 인증은 Burp 세션 규칙/매크로를 사용합니다. 별도로 설치·설정해야 합니다.

2 원본 요청 준비

트래픽에서 하나를 선택한 뒤 Repeater로 준비합니다. 해당 외부 도구의 메뉴에서 직접 실행합니다. 이 버튼만으로 대상 HTTP 요청을 보내지 않습니다.

3 결과 이름을 TSV로 정리

METHOD [탭] URL [탭] URL/BODY/HEADER/COOKIE [탭] 이름으로 정리합니다. 그림의 debug와 X-Preview는 교육용 후보입니다. 외부 도구 원문을 그대로 파싱하는 기능은 아닙니다.

4 발견 상태로 가져오기

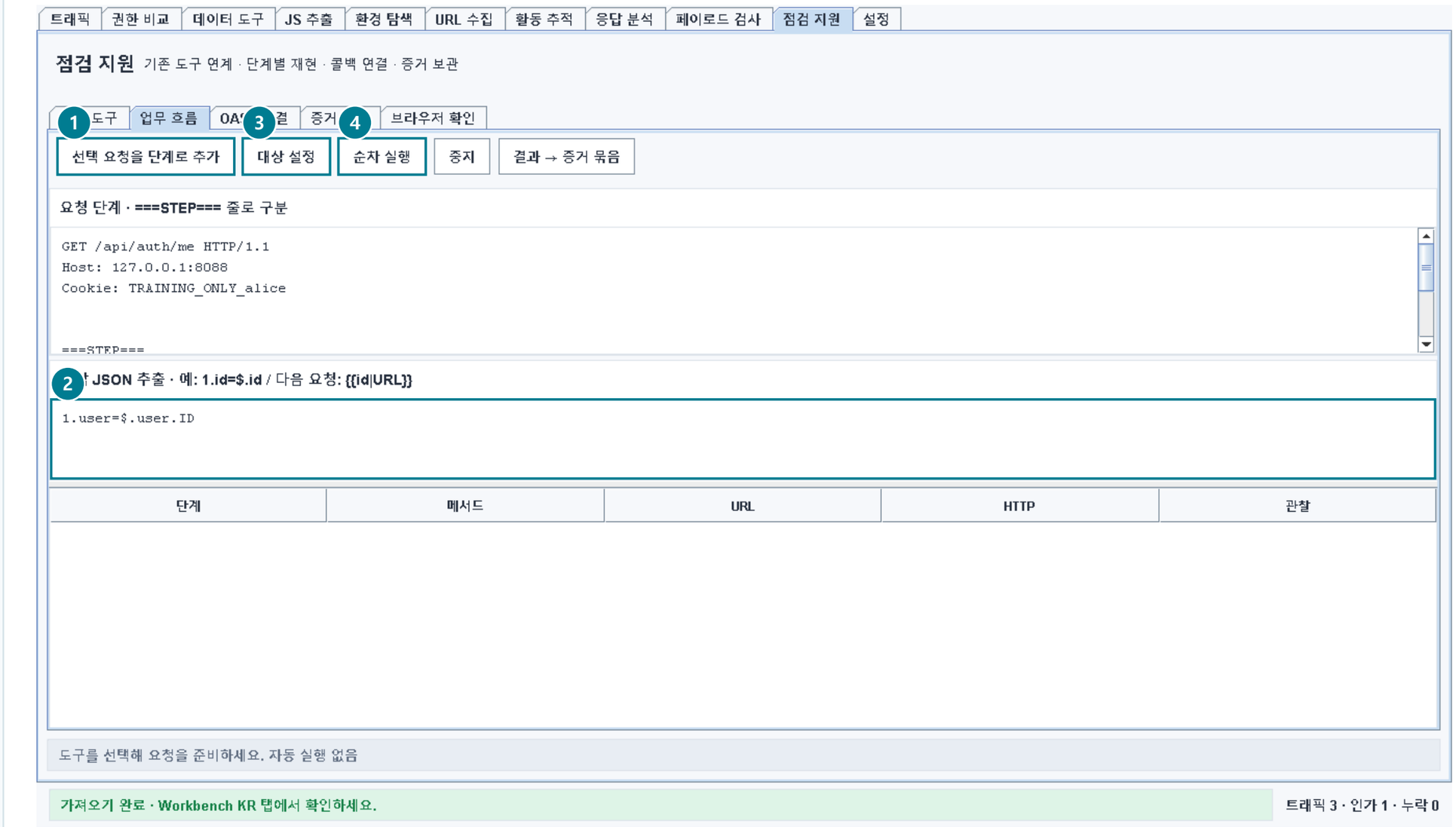
전체 행이 SCOPE와 형식 검증을 통과해야 가져옵니다. 파라미터 값은 가져오지 않습니다. 실제 요청으로 관측하고 진단이 끝난 뒤 완료 처리합니다.

공식 안내에서 원본 문서를 확인할 수 있습니다. 외부 도구를 자동 설치하거나 검사 실행 성공을 자동 판단하지 않습니다.

32 여러 요청을 순서대로 재현

점검 지원 > 업무 흐름

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 요청 단계를 준비

트래픽에서 원본을 선택해 추가합니다. 단계는 ===STEP=== 한 줄로 구분합니다. 원본 인증과 각 요청의 Host·본문을 확인합니다.

2 응답 JSON 값을 다음 단계로 연결

1.id=$.id로 응답의 값을 추출한 뒤 {{id|URL}}, {{id|JSON}}, {{id|RAW}}로 사용합니다. 그림은 계정 조회 후 목록 조회를 준비한 예이며 실행 결과 화면은 아닙니다.

3 대상과 요청 한도 설정

같은 Origin을 지정하고 쓰기 단계 허용·타임아웃·총 요청 한도를 확인합니다. 최대 8단계이며 병렬 요청은 실행하지 않습니다.

4 순서대로 실행하고 최종 상태 확인

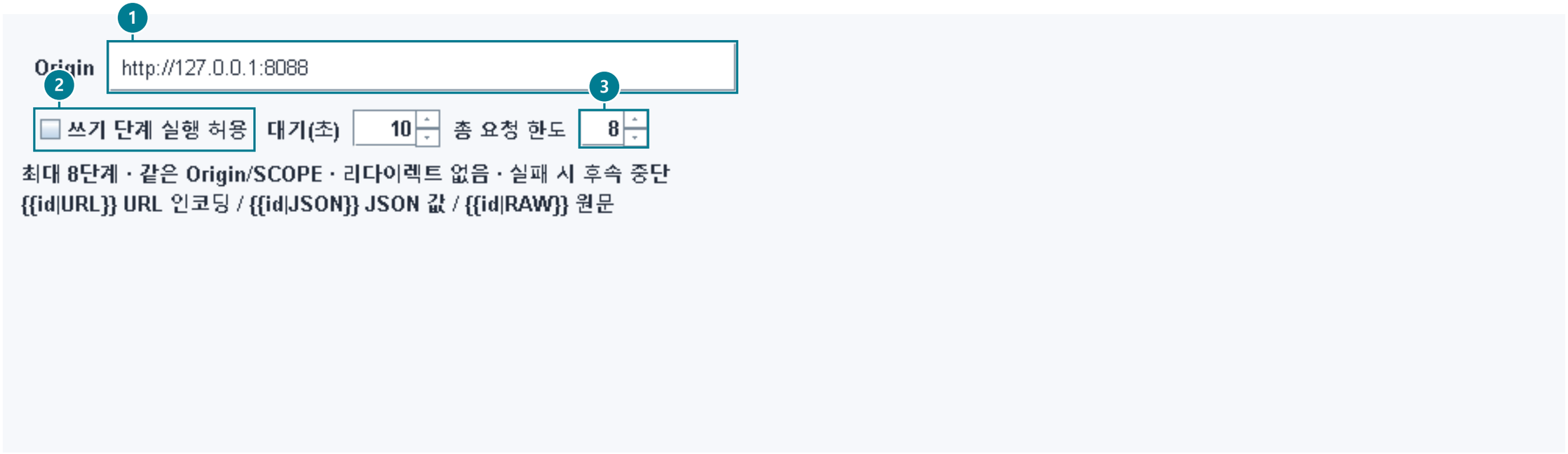
실제 요청을 보냅니다. 실패·리다이렉트·401/403/429/503·추출 실패가 있으면 후속 단계를 중단합니다. 결과를 선택해 원문과 최종 업무 상태를 확인한 뒤 증거 묶음에 추가합니다.

중지는 후속 요청을 중단합니다. 이미 보낸 요청은 응답이나 타임아웃까지 기다립니다. 순서대로 실행되었다는 사실만으로 업무 로직 취약점이 확정되지는 않습니다.

33 업무 흐름 실행 설정

점검 지원 > 업무 흐름 > 대상 설정

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 Origin 제한

프로토콜·호스트·포트만 지정합니다. 모든 단계가 이 Origin 및 Workbench SCOPE 안이어야 합니다.

2 쓰기 요청 선택 허용

POST/PUT/PATCH/DELETE 단계는 이 옵션이 필요합니다. 각 단계의 최종 상태 확인 요청도 준비하세요.

3 한도와 타임아웃

총 요청 한도는 1~20, 단계는 최대 8개입니다. 단계별 응답 대기는 1~120초입니다.

Host 중복, 범위 밖 대상, 앞 단계에 없는 변수, chunked/압축 요청은 실행 준비 단계에서 거부합니다. 요청을 정상화한 후 사용합니다.

34 OAST 상호작용을 원본 요청과 연결

점검 지원 > OAST 연결

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 Pro Collaborator 주소 발급

트래픽의 요청 하나에 콜백 ID를 연결합니다. Pro와 사용 가능한 Collaborator가 필요합니다. 대상 요청에는 자동 삽입·전송하지 않습니다.

2 수동 전송 후 상호작용 확인

콜백 주소를 실제 검사 요청에 넣고 직접 전송한 뒤 조회합니다. ID·유형·시각·원본 URL을 대조하고 실제 원인과 영향을 확인합니다.

3 Community에서는 외부 결과 정리

외부 OAST 결과를 ID [탭] DNS/HTTP/SMTP [탭] 시각 [탭] METHOD [탭] URL로 입력합니다. 그림은 실제 콜백이 아닌 교육용 메타데이터입니다.

4 검토 대상으로 기록

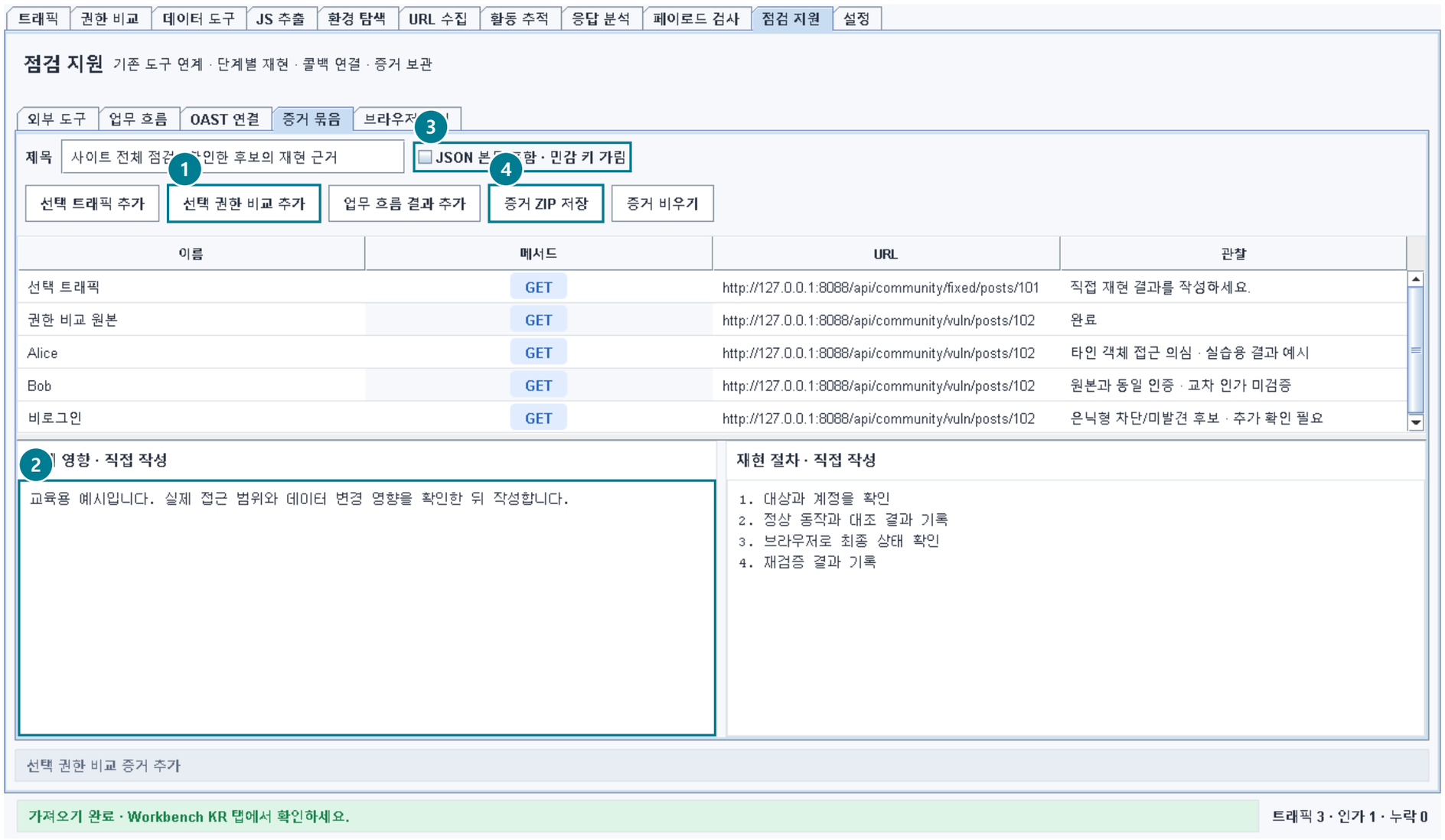
범위·형식 검증 후 중복을 제거하고 활동 추적에 검토 필요를 기록합니다. 외부 결과의 요청 연결은 제공한 URL을 기준으로 합니다.

DNS/HTTP 상호작용만으로 SSRF 등 취약점을 확정하지 않습니다. 이번 배포 검증은 Community 기준이며 Pro Collaborator 외부 서비스 연결은 실제 검증하지 않았습니다.

35 재현 증거를 ZIP으로 보관

점검 지원 > 증거 묶음

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 비교 결과 추가

권한 비교 History에서 하나를 선택한 뒤 원본과 계정별 요청/응답을 가져옵니다. 선택 트래픽이나 끝난 업무 흐름도 추가할 수 있습니다.

2 실제 영향과 재현 절차 작성

대상·계정 조건·기대 동작·실제 동작·영향을 직접 작성합니다. 경고나 HTTP 코드만으로 자동 작성된 취약점 결론을 제출하지 않습니다.

3 본문 포함 여부 결정

기본은 요청/응답 본문 제외입니다. 체크하면 제한된 JSON 본문만 민감 키를 가려 포함합니다. 인증 헤더·쿼리 값은 가리며 비JSON 본문은 제외합니다.

4 보고서와 패킷 묶음 저장

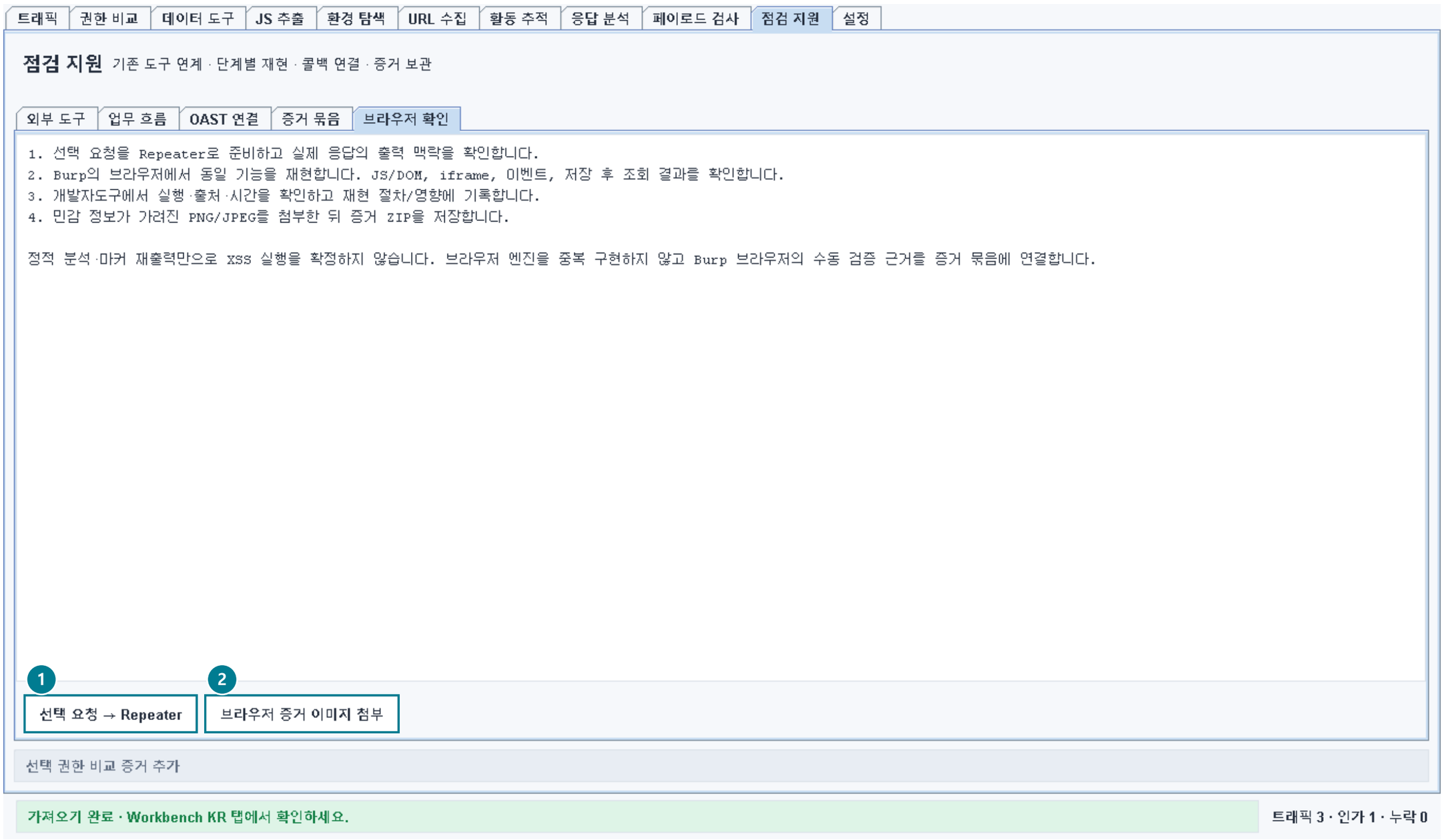
Markdown/HTML 보고서, evidence.json, coverage.json, 요청/응답 .http와 첨부 이미지를 저장합니다. 최대 32개 요청이며 저장 후 가림 결과와 재현 절차를 직접 확인합니다.

제목·영향·재현 절차·이미지는 작성자가 민감 정보를 먼저 가려야 합니다. 가림 처리된 ZIP은 로컬 인증 원본의 대체물이 아닙니다.

36 실제 브라우저 실행 근거 연결

점검 지원 > 브라우저 확인

0.19.0 실습용 예시 화면 · 실제 확장 UI를 창 없이 렌더링



1 원본 응답과 출력 위치 확인

점검할 요청을 준비한 뒤 실제 응답의 출력 맥락을 확인합니다. 실행과 영향 확인은 Burp 브라우저에서 직접 수행합니다.

2 실제 실행 근거 첨부

JS/DOM·iframe·이벤트·저장 후 조회를 재현하고 민감 정보가 가려진 PNG/JPEG를 첨부합니다. 8MB 및 가로·세로 4096px 제한이 있습니다.

별도의 브라우저 엔진을 띄우거나 자동 실행하지 않습니다. 재출력·반사된 문자열과 실제 스크립트 실행을 구별하고 영향/절차와 함께 증거 ZIP에 기록합니다.

제가 점검을 시작한다면 1 / 4

1. 범위와 정상 기능을 먼저 파악합니다

제가 맡은 대상은 게시글·첨부파일·쪽지·검색·계정·관리 기능이 있는 서비스라고 가정하겠습니다. 특정 취약점 하나를 먼저 정하지 않고 기능과 데이터의 흐름부터 살펴보겠습니다.

1 트래픽에서 점검 범위를 등록

Burp 브라우저로 접속한 뒤 Workbench KR > 트래픽 > 요청 행 우클릭 > SCOPE 지정으로 허용된 Origin이나 경로를 등록합니다. SCOPE 목록 창에서 포함 관계를 확인하고 실제 요청이 수집되는지 봅니다.

↓

2 내가 소유한 계정 A·B와 비로그인 동작 비교

각 계정으로 로그인·조회·검색·수정·업로드를 정상 사용합니다. 제공된 관리자 계정이 있으면 관리 기능도 살펴봅니다. 권한 비교 후보에 계정을 지정하고, 소유값·역할·조직·공개/비공개 정책을 실제 서비스 기준으로 정리합니다.

↓

3 사이트를 기능 단위로 둘러보기

목록·상세·댓글·쪽지·다운로드·프로필·관리 메뉴를 따라갑니다. 읽기와 쓰기 요청, 객체 식별자, 숨겨진 입력, 상태 변경 전후를 기록합니다. 응답 분석의 Passive 경고와 활동 추적의 URL·파라미터 목록을 함께 확인합니다.

↓

4 먼저 점검할 후보 고르기

외부에서 입력되는 값, 타인 데이터에 접근하는 기능, 파일 처리, 권한 변경, 여러 단계를 거치는 기능을 우선순위로 둡니다. 단순 HTTP 200이나 경고 개수로 취약점을 결정하지 않고 정상 요청을 비교 기준으로 보관합니다.

예시는 가상의 서비스 전체 점검 흐름입니다. 관리자·조직 기능은 실제 대상에 있고 허용된 계정이 제공된 경우에 포함합니다.

제가 점검을 시작한다면 2 / 4

2. 화면 밖의 API와 입력값까지 수집합니다

정상 화면에서 모은 요청을 출발점으로 JS·API 문서·외부 도구 결과를 연결하겠습니다. 수집된 주소가 실제로 사용 가능한 API인지 하나씩 확인하겠습니다.

1 JS 추출에서 기능과 API 연결

관측한 JS 응답을 분석해 URL/API·메서드·입력 이름을 확인합니다. 계정·파일·검색·관리 관련 주소를 기존 트래픽과 대조합니다. 동적 경로는 내가 소유한 실제 객체 값으로 확정하고 Repeater 초안에서 인증과 본문을 확인합니다.

↓

2 API 문서와 URL 수집으로 빠진 경로 찾기

응답 분석 > API 문서에서 관측한 OpenAPI 경로와 입력 구조를 봅니다. URL 수집은 Burp History / JS부터 시작해 중복 패턴의 대표를 확인합니다. 활동 추적 > 발견만 함에서 아직 요청하지 않은 경로를 골라 정상 동작을 탐색합니다.

↓

3 숨겨진 입력과 GraphQL은 기존 도구 활용

점검 지원 > 외부 도구에서 Param Miner 또는 InQL 안내를 확인하고 선택 요청을 Repeater로 준비합니다. 설치한 도구의 메뉴에서 실행하고, 발견한 입력 이름만 지정 TSV로 정리해 활동 추적으로 가져옵니다. GraphQL은 실제 서비스에 있을 때 분석합니다.

↓

4 환경 탐색은 근거를 비교하며 진행

관측한 기술 정보를 기준으로 관련 후보만 검증합니다. 존재하지 않는 경로의 응답과 비교하고 로그인 화면·공통 200·리다이렉트를 정상 파일 발견으로 오인하지 않는지 봅니다. 새 API가 나오면 1단계의 정상 기능 탐색으로 돌아갑니다.

발견·요청 관측·수동 완료는 서로 다른 상태입니다. Repeater 초안 준비와 TSV 가져오기는 대상 서버에 요청을 보내지 않습니다.

제가 점검을 시작한다면 3 / 4

3. 기능에 맞춰 권한·입력·업무 흐름을 검증합니다

수집한 모든 URL에 같은 검사를 반복하기보다, 각 기능의 입력과 기대 권한을 기준으로 검사 방법을 고르겠습니다. 한 기능에서 나온 후보는 다른 조회·수정·파일 경로까지 연결해 살펴보겠습니다.

1 권한 비교로 계정·역할·조직 경계 확인

게시글·쪽지·첨부파일·프로필·관리 API를 A/B/비로그인으로 비교합니다. 세션·권한 매트릭스에 메서드와 경로별 기대 ALLOW/DENY를 직접 입력합니다. 만료가 있다면 계정별 GET 갱신과 신원 JSON을 설정하고, 실패하거나 세션이 섞인 결과는 보류합니다.

↓

2 입력 맥락에 맞는 페이로드 검사

검색·필터·파일명·본문·외부 URL 등 실제 입력 위치를 하나씩 고릅니다. 페이로드 검사에서 교체 위치·인코딩·기준값·프로필·요청 한도를 설정합니다. 원본과 대조 요청, 응답 차이와 재현 근거를 보고 필요한 후보를 Repeater에서 다시 확인합니다.

↓

3 여러 단계의 상태 변화와 콜백 확인

점검 지원 > 업무 흐름으로 생성→조회→수정 같은 정상 순서를 준비하고 JSON 값 추출로 다음 요청을 연결합니다. 역순·중복 처리 후보는 정상 결과와 최종 상태를 대조합니다. 동시성은 Turbo Intruder로 직접 검증하고, 외부 호출 가능성이 있으면 OAST ID와 요청·시각을 연결합니다.

↓

4 브라우저에서 실제 동작과 영향을 확인

저장/조회 마커로 출력 경로를 찾고 Burp 브라우저에서 실제 DOM·이벤트·출력 맥락을 확인합니다. 응답에 문자열이 나타난 것과 코드 실행을 구별합니다. 데이터 노출·변경, 권한 경계, 업무 상태 등 확인한 영향을 증거 묶음에 직접 작성합니다.

순차 업무 흐름은 최대 8단계이며 쓰기 요청은 실행 설정에서 허용해야 합니다. OAST 상호작용이나 예상 권한 불일치는 추가 검증할 후보입니다.

제가 점검을 시작한다면 4 / 4

4. 누락을 다시 훑고 재현 가능한 증거를 정리합니다

점검은 일회성 스캔으로 끝내지 않겠습니다. 발견한 URL과 입력값을 다시 탐색하고, 기능별 정상/대조 결과를 재검증한 뒤 남은 항목과 확인한 근거를 정리하겠습니다.

1 활동 추적에서 URL과 파라미터 누락 확인

발견만 함·미완료·검토 필요 항목을 확인합니다. URL을 열었다고 모든 입력이 점검된 것은 아니므로 URL·본문·가져온 헤더/쿠키 입력을 따로 봅니다. 완료 처리는 직접 검증이 끝난 항목에만 하고, 변경 관찰을 진단 완료로 간주하지 않습니다.

↓

2 새 경로와 계정 조건으로 다시 확인

JS나 API 문서에서 뒤늦게 찾은 상세·다운로드·수정 경로를 정상 요청으로 연결합니다. A/B/비로그인 조건, 소유 객체, 공개 상태, 역할·조직이 달라져도 결과가 유지되는지 확인합니다. 수정된 기능은 같은 조건에서 재검증합니다.

↓

3 증거 ZIP에 확인한 결과와 영향 보관

선택 트래픽·권한 비교 History·업무 흐름 결과를 증거 묶음에 추가합니다. 제목·실제 영향·재현 절차를 작성하고 민감 정보가 가려진 브라우저 이미지를 첨부합니다. ZIP의 보고서·요청/응답·활동 기록을 열어 재현 순서와 가림 결과를 확인합니다.

↓

4 전체 기능별 점검 상태로 마무리

로그인·계정·게시글·검색·파일·쪽지·관리 기능별로 확인한 범위와 남은 항목을 정리합니다. 발견한 취약점, 검증 중인 후보, 접근 불가/미점검 기능을 구분해 기록합니다. 새로운 API가 생기면 수집→기능 탐색→검증→누락 확인의 흐름을 반복합니다.

증거 ZIP은 기본적으로 본문을 제외하고 인증·쿼리 값을 가립니다. 실제 재현용 인증은 로컬 원본에서 준비하고 저장 ZIP의 민감 정보는 제출 전에 확인하세요.

자주 헷갈리는 동작

화면 결과를 읽을 때 확인할 기준

SCOPE 목록과 설정을 눌렀는데 작업 탭이 그대로입니다.

의도한 동작입니다. 두 기능은 별도 창을 열며 현재 작업 화면을 유지합니다. 창 뒤에 가려진 경우 작업 표시줄 또는 열린 창을 확인하세요.

URL이 있는데 아직 검증된 항목이 아닙니다.

JS나 API 문서에서 발견한 URL은 실제 요청 성공을 뜻하지 않습니다. 활동 추적의 발견만 함, 요청 관측, 수동 완료를 나눠 확인하세요.

q 값을 바꿨는데 파라미터가 완료되지 않습니다.

변경 관찰은 값의 변화가 감지되었다는 뜻입니다. 실제 진단이 끝난 후 파라미터 완료를 누르세요. URL 완료도 별도로 관리합니다.

Repeater 초안을 눌렀는데 트래픽이 증가하지 않습니다.

초안 준비는 전송이 아닙니다. Repeater에서 값·인증을 확인하고 Send를 눌러야 요청이 발생합니다. 권한 비교, GET 검증, 페이로드 시작은 실제 요청을 보냅니다.

표에 HTTP 200 또는 경고가 있으면 취약점인가요?

상태 코드만으로 결론 내리지 않습니다. 공개 정책, 논리적 차단, 없는 경로 기준, 원본 응답과 판정 근거를 함께 확인하고 수동 재현하세요.

글자가 가려지거나 결과 열이 안 보입니다.

창 크기, 표의 가로 스크롤, 분할선을 조정합니다. 설정에서 배치를 바꾸거나 배치 초기화를 사용하세요. 그림의 원본 크기로 보려면 HTML 이미지를 클릭해 확대합니다.